Учреждение «Университет «Туран»
Высшая школа информационных технологий
Образовательная программа 7M06101 — Информационные системы

РУКОВОДСТВО ПОЛЬЗОВАТЕЛЯ

BioAuth Optimizer — программное средство многокритериальной оптимизации параметров систем биометрической аутентификации

Версия 3.1.2

Дисциплина «Методы и инструменты оптимизации»
Самостоятельная работа обучающегося № 2 (СРО2)

Выполнил:
магистрант 2 курса, группа ИС_НПМ_25р
Мекенбаев Даниэль Кайратханович

Проверил(а):
_____

Алматы, 2026

СОДЕРЖАНИЕ

1 ВВЕДЕНИЕ.....4
1.1 Назначение программы.....4
1.2 Кому адресовано руководство.....4
1.3 Основные понятия.....5
2 УСТАНОВКА И ЗАПУСК.....6
2.1 Что понадобится.....6
2.2 Установка Docker.....6
2.3 Получение программы.....6
2.4 Запуск.....7
2.5 Проверка, остановка и перезапуск.....8
3 ИНТЕРФЕЙС ПРОГРАММЫ.....9
4 РАСЧЁТ ОПТИМАЛЬНОГО ПОРОГА.....11
4.1 Быстрый старт: пример из статьи.....11
4.2 Ввод параметров.....12
4.3 Как читать результат.....13
4.4 Ограничение на FAR.....14
4.5 Расчёт по своим оценкам (CSV).....14
4.6 Ошибки ввода.....18
5 ВЫБОР СОСТАВА ФАКТОРОВ.....19
5.1 Быстрый старт: пример из статьи.....19
5.2 Ввод факторов и каталоги.....20
5.3 Ограничения и метод решения.....21
5.4 Как читать результат.....21
5.5 Если допустимых наборов нет.....22
5.6 Чувствительность к бюджету.....23
6 ИСТОРИЯ ЭКСПЕРИМЕНТОВ.....25
7 ЭКСПОРТ РЕЗУЛЬТАТОВ.....27
8 РЕГИСТРАЦИЯ И ВХОД ПО ЛИЦУ.....28

8.1 Регистрация.....28
8.2 Вход.....30
8.3 Профиль.....33
9 АДМИНИСТРИРОВАНИЕ.....35
9.1 Вход сотрудника.....35
9.2 Сводка.....36
9.3 Пользователи и журнал входов.....37
9.4 Измерения.....38
9.5 Калибровка порога.....39
9.6 Политики.....40
9.7 Журнал попыток.....41
9.8 Испытание защиты от атак (PAD).....42
9.9 Пакетный режим.....43
9.10 Протокол «до/после калибровки».....44
9.11 Журнал аудита.....45
10 ВХОД В ДРУГИЕ ПРИЛОЖЕНИЯ ЧЕРЕЗ BIOAUTH (OPENID CONNECT) 47
10.1 Как это выглядит для пользователя.....47
10.2 Демо-клиент.....48
10.3 Подключение своего приложения (для администратора).....49
11 ЯЗЫК, ТЕМА И УСТАНОВКА КАК ПРИЛОЖЕНИЕ.....51
12 ПРОГРАММНЫЙ ИНТЕРФЕЙС ДЛЯ ИНТЕГРАЦИИ.....52
13 СООБЩЕНИЯ ОБ ОШИБКАХ.....54
14 ЧАСТЫЕ ВОПРОСЫ.....55
15 ТИПОВОЙ СЦЕНАРИЙ: НАСТРОЙКА ВХОДА В БАНКОВСКОЕ ПРИЛОЖЕНИЕ.....57

1 ВВЕДЕНИЕ

1.1 Назначение программы

BioAuth Optimizer помогает настроить систему биометрической аутентификации так, чтобы ожидаемые потери от ошибок были минимальными. Программа отвечает на три вопроса:

- **какой порог сравнения выставить**, если известно, во сколько раз пропуск злоумышленника дороже отказа законному пользователю;
- **какие факторы включить в процедуру входа** (лицо, отпечаток, голос, аппаратный ключ и т. д.), чтобы уложиться в ограничения по времени входа, бюджету и требованиям безопасности;
- **как изменится лучшее решение**, если урезать или увеличить бюджет.

Каждый расчёт сохраняется в истории; результаты можно выгрузить в JSON, CSV и PNG для отчёта.

Начиная с версии 2 программа также выполняет настоящий вход по лицу с проверкой «живости» и passkey, собирает собственные оценки и по ним калибрует пороги тем же методом — замкнутый контур (разделы 8 и 9). Версия 3 добавляет профиль с историей входов, админ-панель и вход в другие приложения через BioAuth по протоколу OpenID Connect (разделы 8–10), интерфейс на русском, казахском и английском языках, тёмную тему и установку как приложение (раздел 11).

1.2 Кому адресовано руководство

Руководство рассчитано на пользователя без навыков программирования: инженера по безопасности, аналитика, студента или преподавателя. Нужно уметь пользоваться браузером и один раз выполнить несколько команд в терминале для запуска (раздел 2). Математику метода знать не обязательно: она описана в документе «Техническое описание».

1.3 Основные понятия

Таблица 1 — Термины и обозначения

Термин	Значение
Оценка сходства (score)	Число, которое сравнитель выдаёт при сравнении образца с эталоном: чем больше, тем больше сходство
Порог τ	Если оценка не меньше порога, пользователь допускается
Законные пользователи (genuine)	Попытки, в которых образец и эталон принадлежат одному человеку
Злоумышленники (impostor)	Попытки, в которых образец принадлежит другому человеку
FAR — ложный допуск	Доля попыток злоумышленников, которые система пропустила
FRR — ложный отказ	Доля попыток законных пользователей, которые система отвергла
EER — точка равных ошибок	Порог, при котором FAR = FRR; часто используется по умолчанию
c_{FA}, c_{FR} — стоимости ошибок	Цена одного ложного допуска и одного ложного отказа. Важно только их отношение: c_{FA} = 10, c_{FR} = 1 означает, что пропуск злоумышленника в 10 раз дороже отказа
E — ожидаемые потери	$E = c_{FA} \cdot FAR + c_{FR} \cdot FRR$ — средняя цена ошибок на одну попытку. Программа ищет решение с минимальным E
Фактор	Отдельный способ проверки: лицо, отпечаток, голос, аппаратный ключ FIDO2 и т. д.
PAD	Обнаружение атак на предъявление: защита от фотографии, маски, муляжа пальца
Правило «И»	Пользователь должен пройти все включённые факторы
Passkey	Ключ входа FIDO2/WebAuthn, хранящийся на устройстве и подтверждаемый отпечатком пальца, Face ID или PIN-кодом устройства
Политика аутентификации	Утверждённый набор шагов входа и порогов (τ_{face}, τ_{pad}, число команд, passkey); действует ровно одна версия
APCER, BPCER	Доля пропущенных атак на предъявление и доля подлинных предъявлений, ошибочно принятых за атаку (ISO/IEC 30107-3)

2 УСТАНОВКА И ЗАПУСК

2.1 Что понадобится

Таблица 2 — Требования к компьютеру

Параметр	Требование
Операционная система	Windows 10/11 (с WSL 2), macOS 12 и новее, Linux
Память и диск	Не менее 4 ГБ оперативной памяти и 5 ГБ свободного места
Docker	Docker Desktop (Windows, macOS) или Docker Engine с Compose v2 (Linux)
Браузер	Chrome, Edge, Firefox или Safari последних версий
Камера (для входа по лицу)	Встроенная или USB-камера; работает только на localhost или по HTTPS
Интернет	Нужен только при первом запуске, чтобы скачать базовые образы

2.2 Установка Docker

1) Скачайте Docker Desktop с сайта docker.com и установите его, следуя указаниям установщика. В Linux установите пакеты docker и docker-compose-plugin из репозитория дистрибутива.
2) Запустите Docker Desktop и дождитесь, пока индикатор станет зелёным (Docker is running).
3) Проверьте установку: откройте терминал (в Windows — PowerShell) и выполните команду `docker compose version`. Должен появиться номер версии.

2.3 Получение программы

Распакуйте архив `bioauth-optimizer-2.0.0.zip` в любую папку, например в «Документы». Если у вас есть доступ к репозиторию, программу можно получить командой:

```
git clone https://github.com/DcNi3L/bioauth-optimizer.git
```

2.4 Запуск

Откройте терминал в папке программы (в ней лежит файл `docker-compose.yml`) и выполните одну из команд:

```
make up                                  # macOS, Linux
docker compose up -d --build --wait      # любая система, в том числе Windows
```

Первый запуск занимает несколько минут: Docker скачивает базовые образы и собирает программу. Повторные запуски проходят за секунды. Команда завершится, когда все четыре компонента (база данных, сервис распознавания, сервер и интерфейс) будут готовы.

После запуска откройте в браузере адрес **http://localhost:3000** — появится главная страница (рисунок 1). Документация API для разработчиков доступна по адресу http://localhost:4000/api/docs.

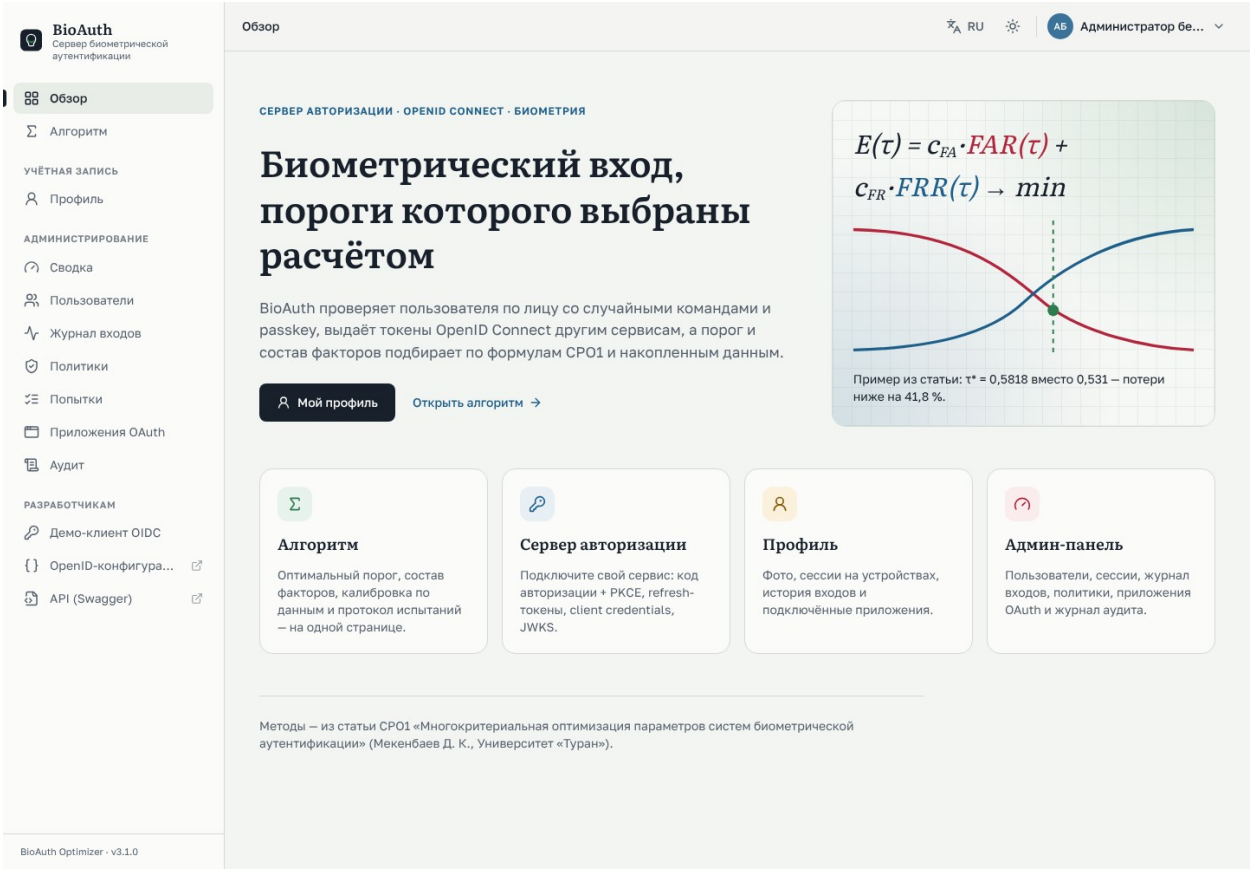


Рисунок 1 — Главная страница

2.5 Проверка, остановка и перезапуск

Таблица 3 — Команды управления

Действие	macOS, Linux	Любая система
Проверить, что всё работает	make health	docker compose ps
Посмотреть журнал сервера	make logs SERVICE=api	docker compose logs -f api
Остановить (данные сохраняются)	make down	docker compose down
Запустить снова	make up	docker compose up -d --wait
Удалить все данные	make reset-db	docker compose down -v
Загрузить демонстрационный каталог из 10 факторов	make demo	см. раздел 5.2

Если порт 3000 или 4000 уже занят другой программой, остановите её или измените порты в `docker-compose.yml`.

3 ИНТЕРФЕЙС ПРОГРАММЫ

Слева находится **боковая панель** со всеми разделами (на телефоне она открывается кнопкой меню в левом верхнем углу):

- **Обзор** — главная страница с кратким описанием возможностей;
- **Алгоритм** — все расчёты на одной странице во вкладках: «Порог» (раздел 4), «Состав факторов» (раздел 5), «История» (раздел 6); сотрудникам дополнительно видны «Измерения», «Калибровка», «Протокол», «Пакетный режим» и «Испытание PAD» (раздел 9);
- **Учётная запись** — «Вход» или «Профиль» (раздел 8) и «Регистрация» для новых пользователей;
- **Администрирование** — видно сотрудникам: сводка, пользователи, журнал входов, политики, попытки, приложения OAuth, аудит (раздел 9);
- **Разработчикам** — демо-клиент OpenID Connect (раздел 10), документ обнаружения и справочник API Scalar (раздел 12).

В **верхней панели** справа — переключатель языка (русский, казахский, английский), переключатель темы (светлая, тёмная, как в системе) и кнопка учётной записи с фото: из её меню открываются профиль, безопасность, история входов и выход. Выбор языка и темы запоминается в браузере. Формы расчётных вкладок и экраны политик, попыток и аудита пока доступны только на русском языке.

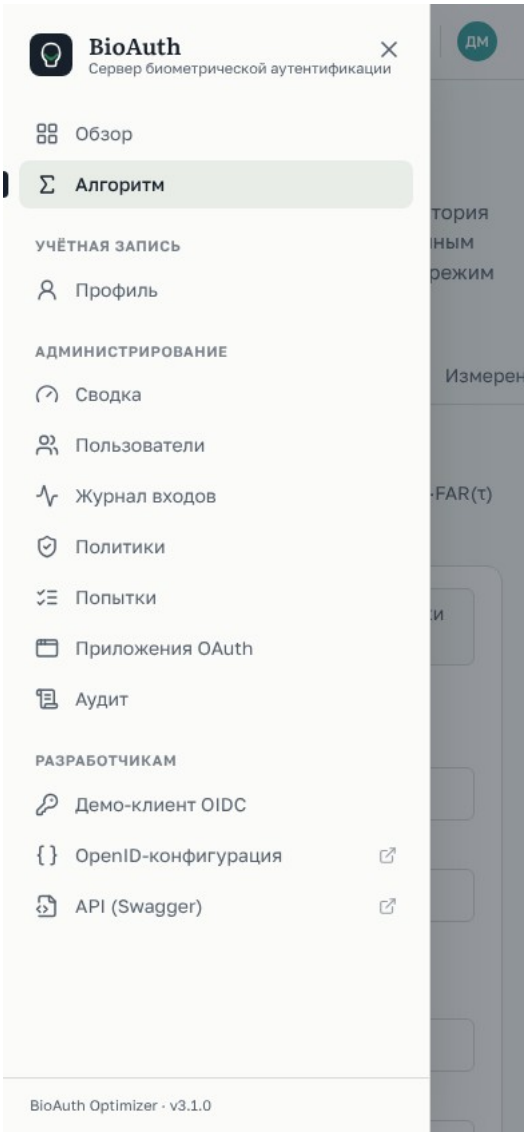


Рисунок 2 — Боковая панель на телефоне

Общие правила ввода:

– дробные числа можно вводить с запятой или точкой: 0,72 и 0.72 равнозначны;
– малые вероятности удобно вводить в экспоненциальной записи: 1e-4 означает 0,0001, 5e-5 — 0,00005;
– ошибка ввода показывается красным под полем, расчёт не запускается, пока она не исправлена;
– кнопка **«Пример из статьи CPO1»** заполняет форму данными модельного примера из статьи — удобно, чтобы познакомиться с программой.

4 РАСЧЁТ ОПТИМАЛЬНОГО ПОРОГА

4.1 Быстрый старт: пример из статьи

1) Откройте **«Алгоритм»** → вкладка **«Порог»**.
2) Нажмите **«Пример из статьи CPO1»**. Поля заполнятся: $\mu_G = 0{,}72$, $\sigma_G = 0{,}09$, $\mu_I = 0{,}3$, $\sigma_I = 0{,}11$, $c_{FA} = 10$, $c_{FR} = 1$.
3) Нажмите **«Рассчитать»**.

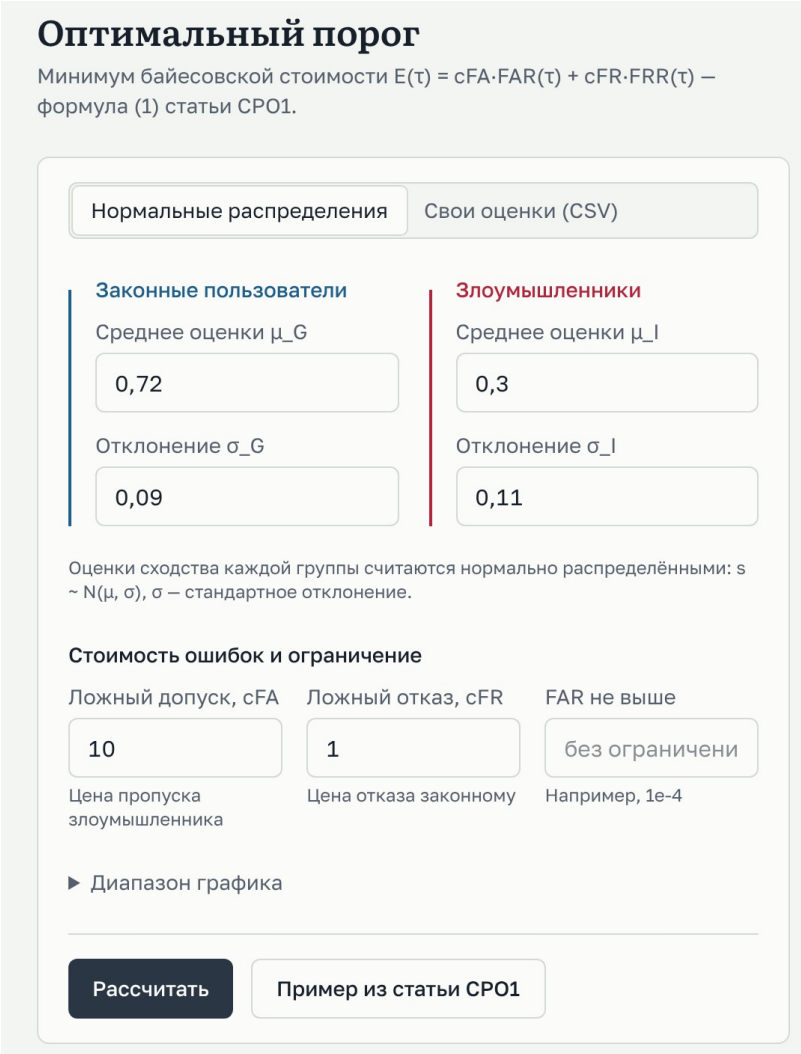


Рисунок 3 — Форма расчёта порога, заполненная данными статьи CPO1

Справа появятся результат и графики (рисунок 4). Оптимальный порог $\tau^* = 0{,}5818$ вместо порога равных ошибок 0,531; ожидаемые потери снижаются на 41,8 %. Ниже результата строится ROC-кривая.

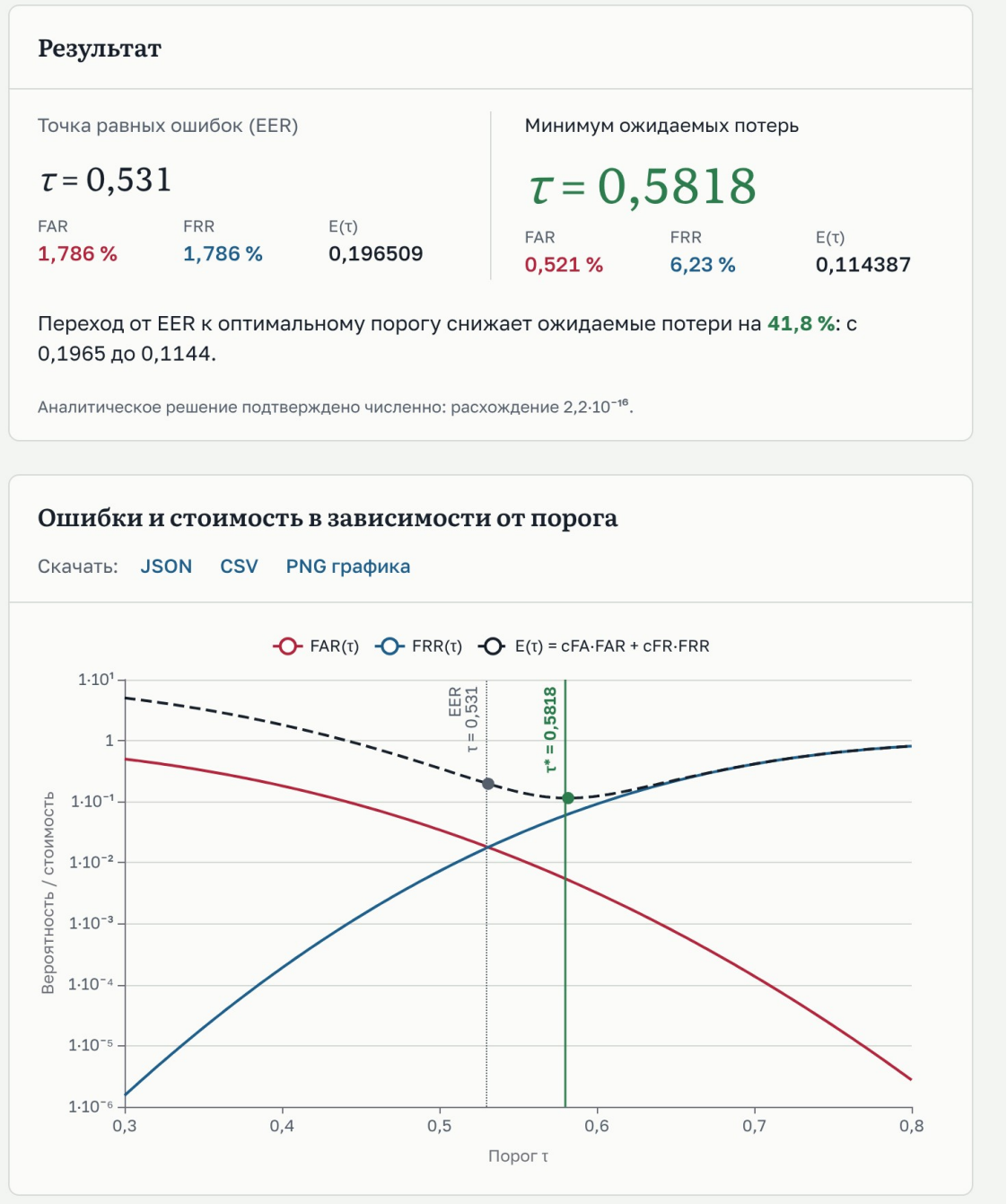


Рисунок 4 — Результат расчёта порога и график ошибок

4.2 Ввод параметров

Переключатель вверху формы выбирает источник оценок: **«Нормальные распределения»** (параметры задаются вручную) или **«Свои оценки (CSV)»** (раздел 4.5).

Таблица 4 — Поля формы расчёта порога

Поле	Что вводить	Пример
Среднее оценки μ_G	Среднее значение оценок законных пользователей	0,72
Отклонение σ_G	Стандартное отклонение оценок законных пользователей (> 0)	0,09
Среднее оценки μ_I	Среднее значение оценок злоумышленников; должно быть меньше μ_G	0,3
Отклонение σ_I	Стандартное отклонение оценок злоумышленников (> 0)	0,11
Ложный допуск, c_{FA}	Цена пропуска злоумышленника (> 0)	10
Ложный отказ, c_{FR}	Цена отказа законному пользователю (> 0)	1
FAR не выше	Необязательно. Предельно допустимая доля ложных допусков	1e-4
Диапазон графика	Необязательно. Границы оси порога на графиках («τ от», «τ до»)	0,3 … 0,8

Как выбрать стоимости. Достаточно оценить порядок отношения. Например, если мошенническая операция в среднем приносит ущерб 500 000 тенге, а отказ клиенту (звонок в поддержку, повторная попытка, уход к конкуренту) обходится в 2 500 тенге, задайте $c_{FA} = 200$, $c_{FR} = 1$.

4.3 Как читать результат

Панель **«Результат»** состоит из двух колонок:

– **«Точка равных ошибок (EER)»** — порог, при котором FAR = FRR, и ожидаемые потери E при нём. Это привычная отправная точка;

– **«Минимум ожидаемых потерь»** — оптимальный порог τ* и значения FAR, FRR, E при нём.

Под колонками указано, на сколько процентов переход от EER к τ* снижает ожидаемые потери, и строка о проверке: аналитическое решение подтверждается независимым численным расчётом, расхождение обычно не превышает 10^{-12}.

График «Ошибки и стоимость в зависимости от порога» показывает FAR (красная линия), FRR (синяя) и E (пунктир) на логарифмической шкале. Вертикальные линии отмечают EER и τ*. Видно, что минимум пунктирной

кривой E не совпадает с пересечением FAR и FRR, — в этом и состоит выигрыш метода. **ROC-кривая** показывает долю верных допусков законных пользователей (1 − FRR) в зависимости от FAR; точки отмечают оба порога. Наведите курсор на график, чтобы увидеть точные значения.

Особые случаи. Если стоимости ошибок очень несимметричны (например, $c_{FA}/c_{FR} = 10^6$), минимальные потери может давать решение «отвергать всех» или «допускать всех». Программа сообщит об этом: порог в такой ситуации не имеет смысла, и нужно пересмотреть стоимости или улучшить сравнитель.

4.4 Ограничение на FAR

Если регулятор или политика безопасности требуют, чтобы FAR не превышал заданного значения, введите его в поле **«FAR не выше»** (например, 1e-4). Программа найдёт порог с минимальными потерями среди тех, где FAR не больше заданного. Если безусловный оптимум нарушает ограничение, оптимальным становится наименьший порог, при котором ограничение выполняется.

4.5 Расчёт по своим оценкам (CSV)

Если у вас есть результаты испытаний сравнителя — оценки сходства для пар «свой — свой» и «свой — чужой», — программа найдёт оптимальный порог прямо по ним, без предположения о нормальном распределении.

Формат файла

Текстовый CSV-файл с заголовком и двумя колонками: оценка и метка.

```
score,label
0.652226,genuine
0.824224,genuine
0.301178,impostor
0.412950,impostor
```

Таблица 5 — Правила формата CSV

Элемент	Допустимые значения
Заголовок колонки оценки	score, оценка, similarity, s
Заголовок колонки метки	label, метка, class, type
Метка законного пользователя	genuine, g, 1, true, законный, mated
Метка злоумышленника	impostor, imposter, i, 0, false, злоумышленник, nonmated, non-mated
Разделитель	запятая, точка с запятой или табуляция (определяется автоматически)
Десятичный разделитель	точка; при разделителе «;» или табуляции допускается запятая (формат Excel)
Объём	до 1 000 000 строк и 50 МБ; нужна хотя бы одна оценка каждой группы
Прочее	метка BOM и пустые строки допускаются; лишние колонки игнорируются

Порядок действий

1) В разделе «Порог» переключитесь на **«Свои оценки (CSV)»**.
2) Нажмите на область **«Выберите CSV-файл с оценками»** и выберите файл. Для пробы подойдёт `examples/scores-demo.csv` из папки программы — 20 000 синтетических оценок из распределений статьи.
3) После загрузки появится карточка набора: число оценок каждой группы, диапазон и гистограмма. Убедитесь, что гистограммы двух групп разнесены, как на рисунке 5.
4) Задайте стоимости ошибок и нажмите **«Рассчитать»**.



Рисунок 5 — Загруженный набор оценок: объёмы групп и гистограмма

Результат расчёта по оценкам показан на рисунке 6. Кривые FAR и FRR здесь ступенчатые, потому что вычисляются по конечной выборке.

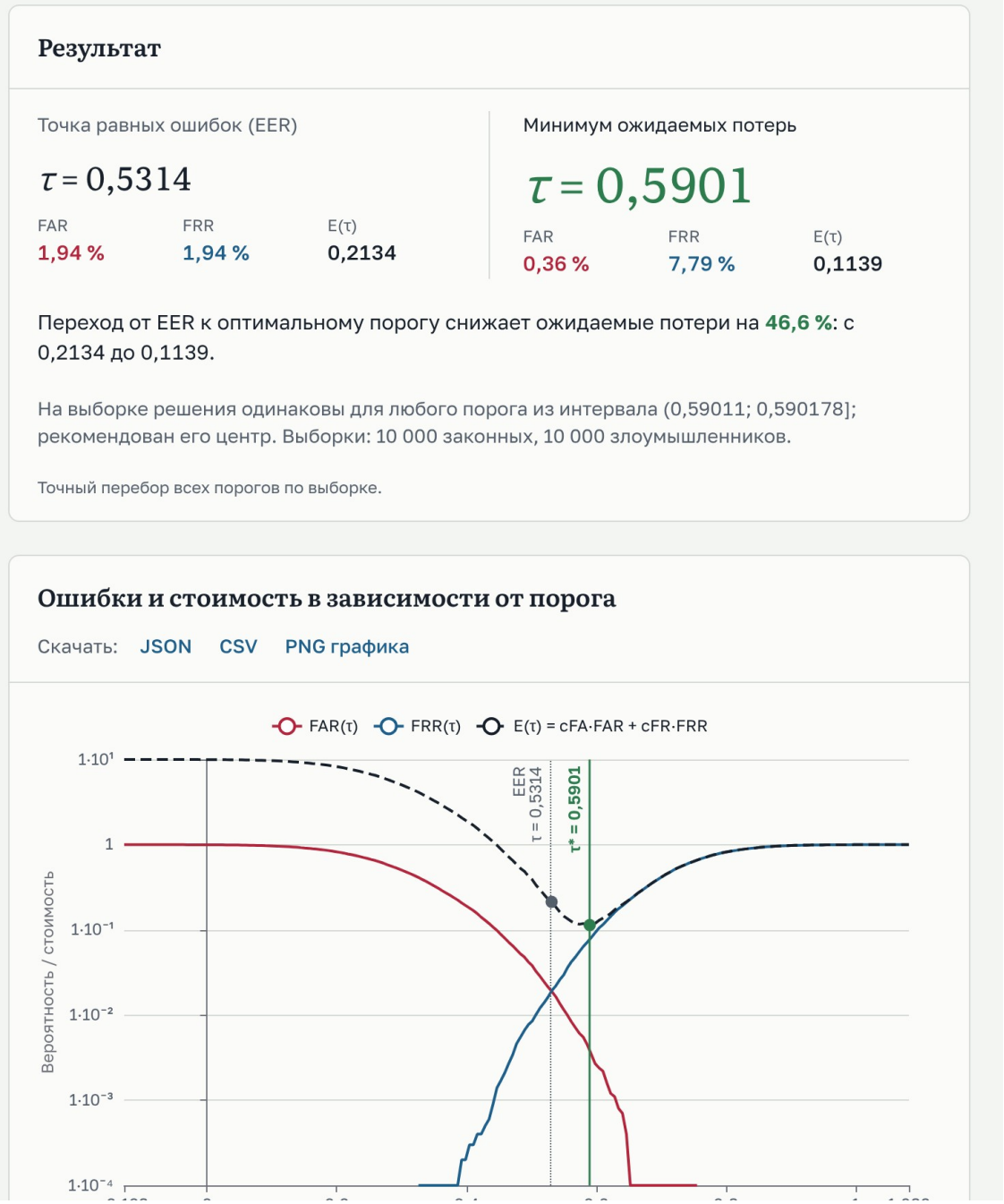


Рисунок 6 — Результат расчёта порога по загруженным оценкам

В эмпирическом режиме результат одинаков для любого порога из некоторого интервала между соседними оценками. Программа указывает этот интервал и рекомендует его середину. Повторная загрузка того же файла не создаёт дубликат.

Предупреждение о недостатке данных. Чтобы подтвердить, что FAR не выше p, нужно не меньше 3/p попыток злоумышленников без ложных допусков (правило трёх). Если оценок злоумышленников меньше, программа предупредит, что заявленный FAR статистически не подтверждён.

4.6 Ошибки ввода

Программа проверяет данные до отправки на сервер. Неверное значение выделяется красным, а под полем появляется пояснение (рисунок 7). Например, среднее оценок законных пользователей должно быть больше среднего злоумышленников: иначе сравнитель работает «наоборот» и порог теряет смысл.

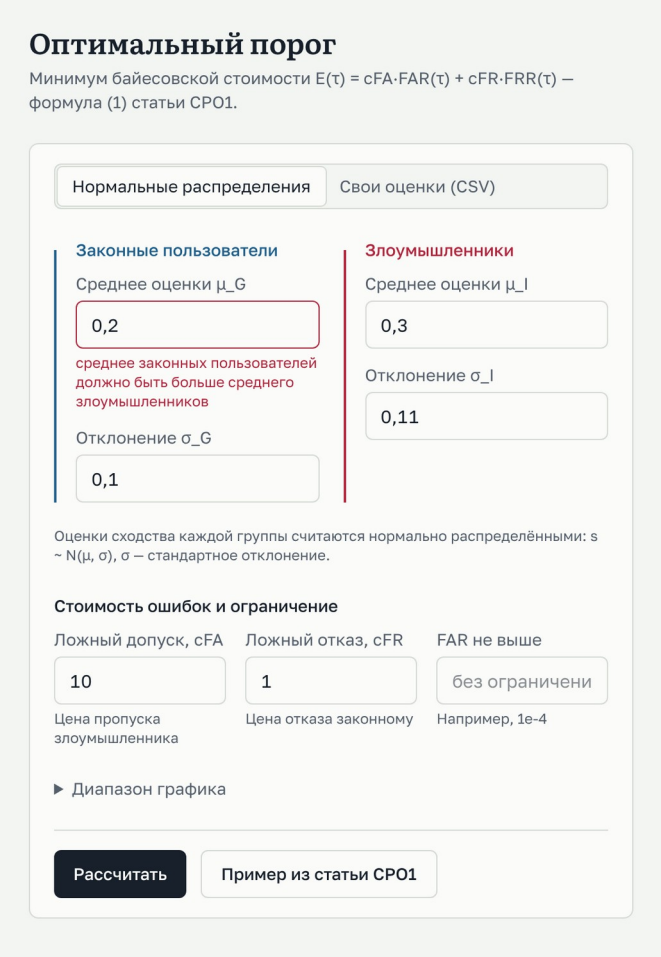


Рисунок 7 — Сообщение об ошибке ввода

5 ВЫБОР СОСТАВА ФАКТОРОВ

5.1 Быстрый старт: пример из статьи

1) Откройте **«Алгоритм»** → вкладка **«Состав факторов»**.
2) Нажмите **«Пример из статьи СРО1»** (справа вверху). Таблица заполнится пятью факторами F1–F5, а форма ограничений — значениями из статьи (рисунок 8).
3) Нажмите **«Подобрать набор»**.

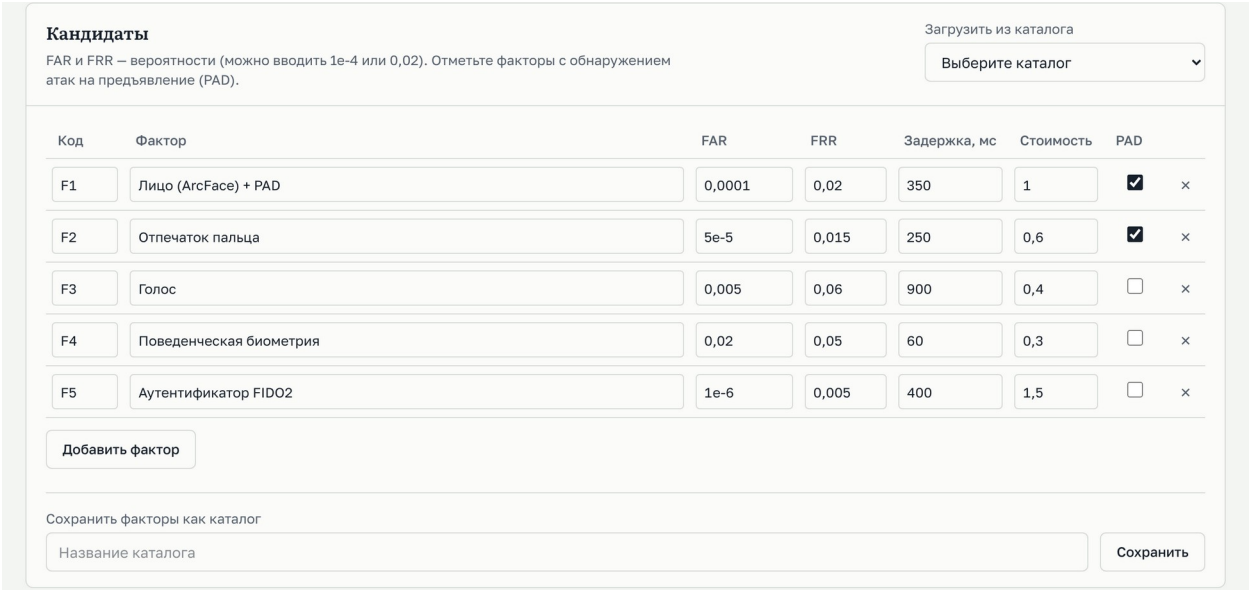


Рисунок 8 — Таблица факторов-кандидатов

Результат: оптимальный набор **F2 + F5** (отпечаток пальца и аппаратный ключ FIDO2) с ожидаемыми потерями 0,019925; допустимы 6 наборов из 31 (рисунок 9).

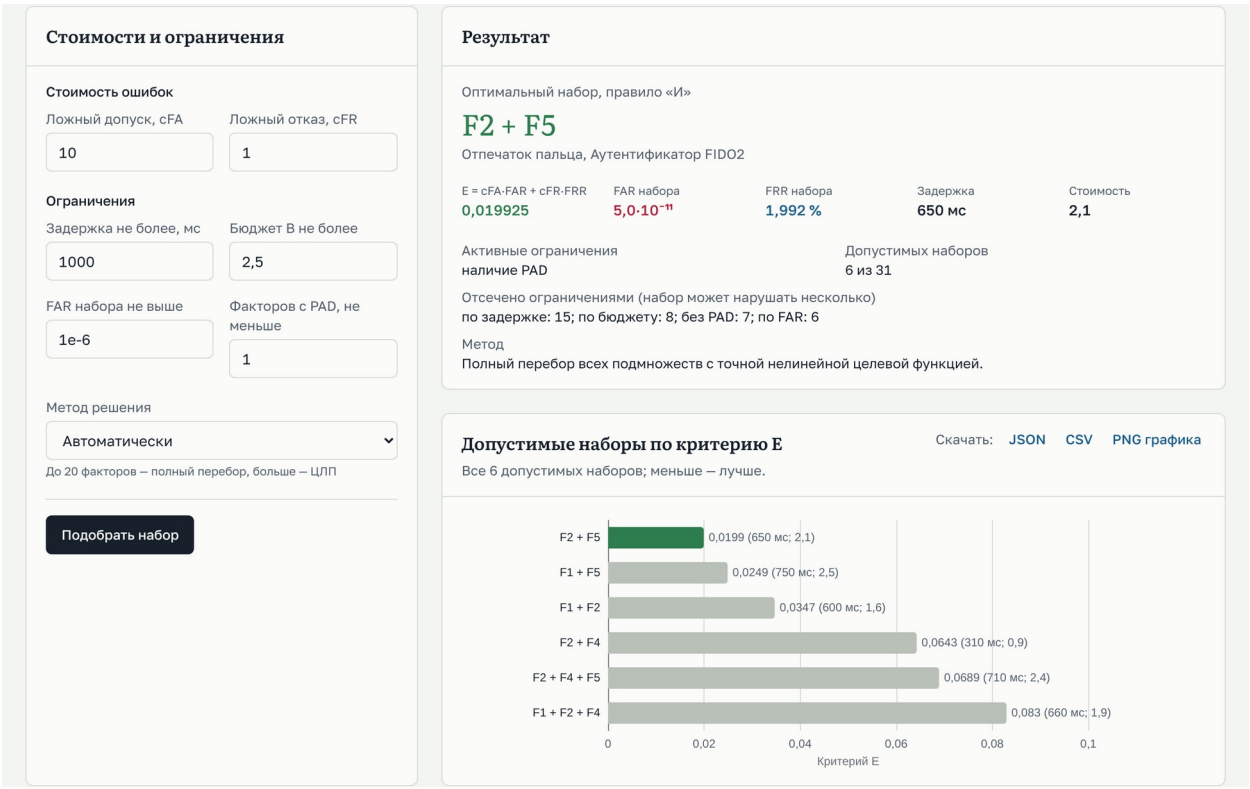


Рисунок 9 — Ограничения, результат и рейтинг допустимых наборов

5.2 Ввод факторов и каталоги

Каждая строка таблицы **«Кандидаты»** — один фактор:

Таблица 6 — Поля фактора

Поле	Что вводить
Код	Короткий уникальный код, например F1 (до 16 символов)
Фактор	Название, например «Отпечаток пальца»
FAR	Вероятность ложного допуска фактора, строго между 0 и 1 (например, 5e-5)
FRR	Вероятность ложного отказа, от 0 включительно до 1 (например, 0,015)
Задержка, мс	Время прохождения фактора в миллисекундах
Стоимость	Затраты на фактор в любых единицах (на пользователя, на точку входа)
PAD	Отметьте, если фактор обнаруживает атаки на предъявление

– **«Добавить фактор»** добавляет пустую строку, крестик справа удаляет строку. Можно задать от 1 до 50 факторов.
– **«Загрузить из каталога»** заполняет таблицу сохранённым каталогом. Каталог «СРО1 — модельный пример (табл. 2)» установлен заранее.

– **«Сохранить факторы как каталог»**: введите название и нажмите «Сохранить» — каталог появится в списке и сохранится между запусками.

Демонстрационный каталог из 10 факторов (добавлены радужка, вены ладони, SMS-код, PIN, смарт-карта) загружается командой `make demo` или из файла `examples/catalog-10-factors.json` через справочник API Scalar (метод POST /api/v1/factor-catalogs).

5.3 Ограничения и метод решения

Таблица 7 — Поля панели «Стоимости и ограничения»

Поле	Смысл
Ложный допуск, c_{FA} / Ложный отказ, c_{FR}	Стоимости ошибок — как в расчёте порога
Задержка не более, мс	Суммарное время всех факторов набора. Пустое поле — без ограничения
Бюджет B не более	Суммарная стоимость факторов набора. Пустое поле — без ограничения
FAR набора не выше	Предельный FAR набора (произведение FAR факторов)
Факторов с PAD, не меньше	Сколько факторов набора должны иметь PAD (по умолчанию 1)
Метод решения	«Автоматически» — полный перебор до 20 факторов, иначе целочисленное программирование; «Полный перебор» — все $2^n - 1$ наборов (до 20 факторов), даёт полный рейтинг; «Целочисленное программирование (HiGHS)» — метод статьи CPO1 с доказательством оптимальности, до 50 факторов

5.4 Как читать результат

– **Оптимальный набор** — коды и названия факторов с минимальными ожидаемыми потерями при правиле «И».
– **E, FAR набора, FRR набора, задержка, стоимость** — характеристики оптимального набора.
– **Активные ограничения** — ограничения, которые выполняются «впритык» и мешают найти лучший набор. Ослаблять имеет смысл именно их. В примере статьи активно только требование PAD; задержка 650 мс меньше предела 1000 мс.

– **Допустимых наборов** — сколько наборов из всех возможных удовлетворяют ограничениям.
– **Отсечено ограничениями** — сколько наборов нарушает каждое ограничение (один набор может нарушать несколько).
– **Метод** — каким решателем получен результат.
– **«Допустимые наборы по критерию E»** — диаграмма рейтинга: чем короче полоса, тем лучше; оптимум выделен зелёным, в подписи — задержка и стоимость.

При методе «Целочисленное программирование» программа сообщает число итераций и нижнюю оценку, которая доказывает оптимальность найденного набора (рисунок 10). Рейтинг в этом режиме содержит только просмотренные наборы.

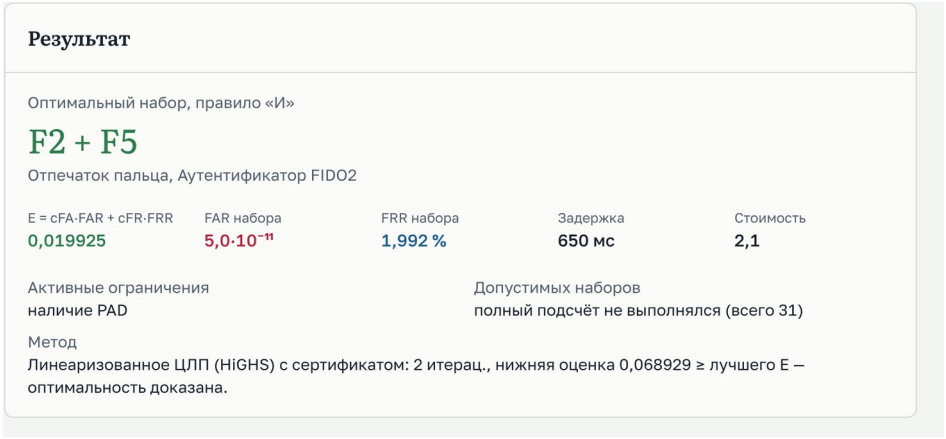


Рисунок 10 — Результат метода целочисленного программирования с доказательством оптимальности

5.5 Если допустимых наборов нет

Если ни один набор не удовлетворяет ограничениям, программа показывает, какие ограничения мешают чаще всего (рисунок 11). Ослабьте самое жёсткое из них — обычно бюджет или задержку — и повторите расчёт.

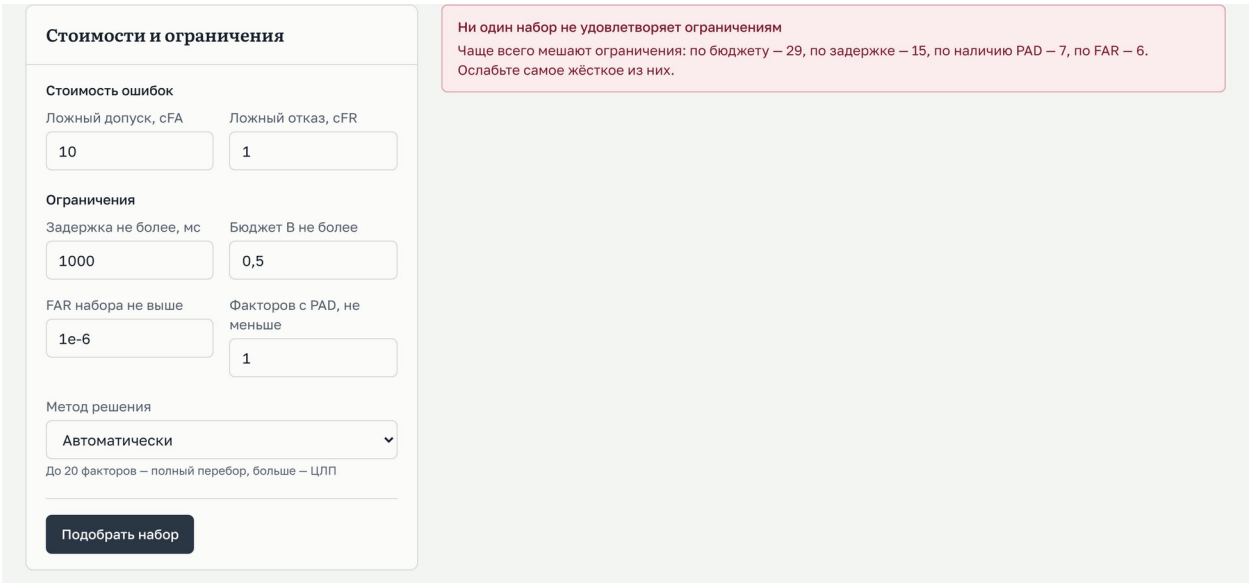


Рисунок 11 — Диагностика недопустимой задачи (бюджет 0,5)

5.6 Чувствительность к бюджету

Панель **«Чувствительность к бюджету»** отвечает на вопрос: что будет, если бюджет изменится, а остальные ограничения останутся прежними.

1) Задайте диапазон: **«Бюджет от»**, **«до»** и **«шаг»** (не более 500 точек).
2) Нажмите **«Построить»**.

Ступенчатый график показывает лучшие потери E* при каждом бюджете, таблица — бюджеты, при которых меняется оптимальный набор, и во сколько раз снижаются потери при переходе на следующую ступень (рисунок 12). В примере статьи увеличение бюджета с 1,6 до 2,1 меняет набор F1 + F2 на F2 + F5 и снижает потери в 1,74 раза; при бюджете меньше 0,9 допустимых наборов нет.

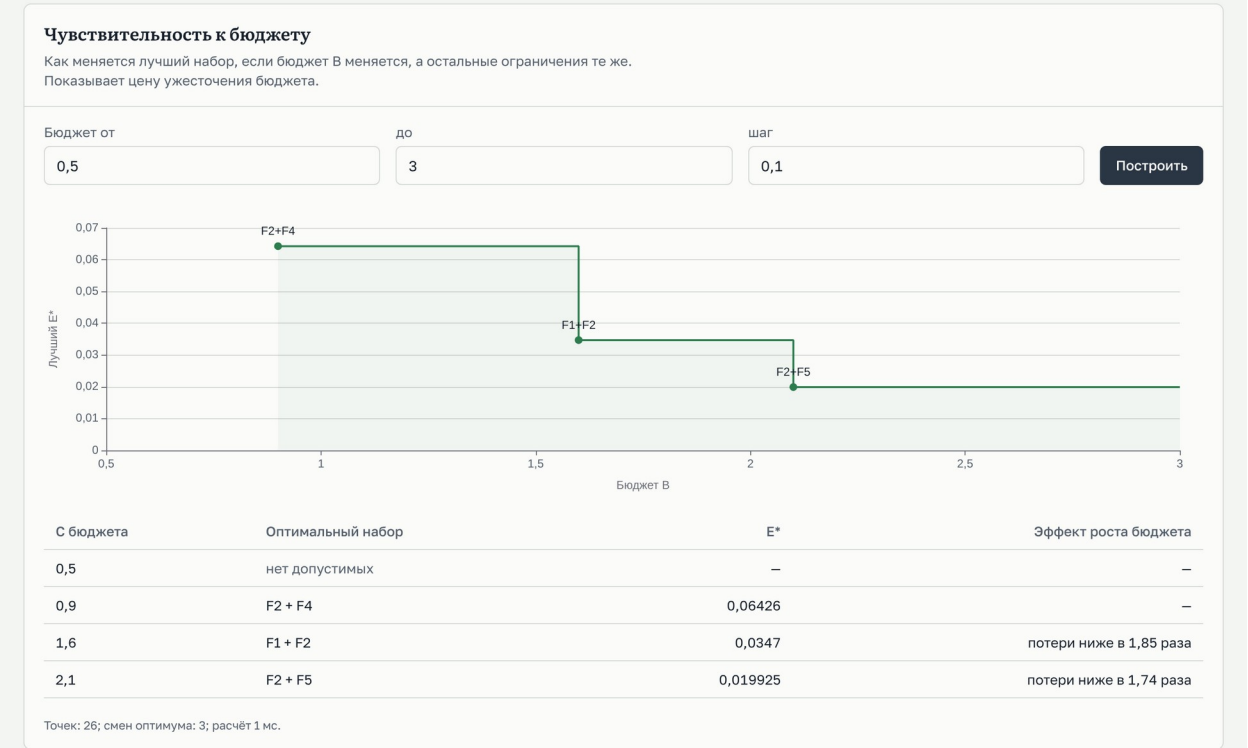


Рисунок 12 — Анализ чувствительности к бюджету

6 ИСТОРИЯ ЭКСПЕРИМЕНТОВ

Каждый расчёт автоматически сохраняется. Вкладка **«Алгоритм → История»** показывает список экспериментов: время, тип задачи, краткий результат, метод и время расчёта (рисунок 13). Переключатель вверху фильтрует список по типу: «Порог», «Состав факторов», «Анализ бюджета».

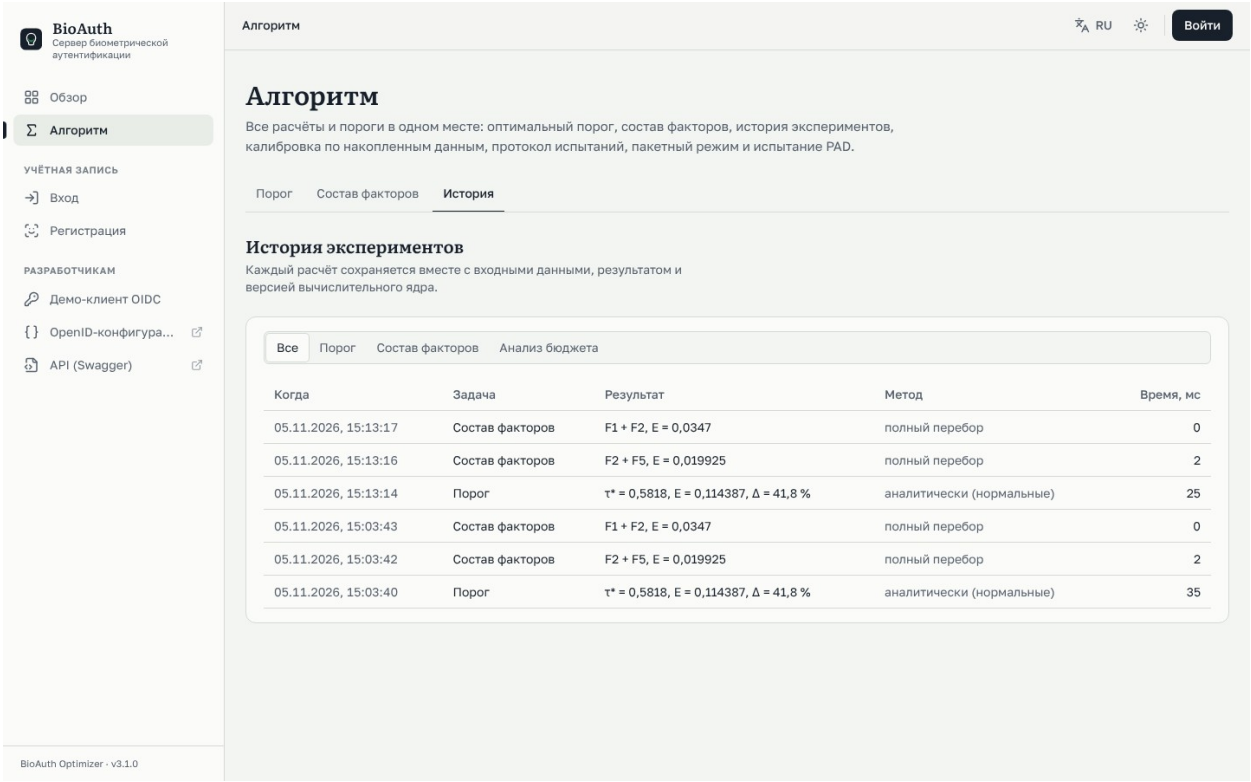


Рисунок 13 — История экспериментов

Нажмите на строку, чтобы открыть эксперимент (рисунок 14). Карточка содержит результат в том же виде, что и при расчёте, и раздел **«Входные данные и полный результат»**: кнопка «Показать JSON» раскрывает все данные, «JSON» — скачивает их. В карточке указаны версия вычислительного ядра и время расчёта, поэтому эксперимент можно воспроизвести и приложить к отчёту.

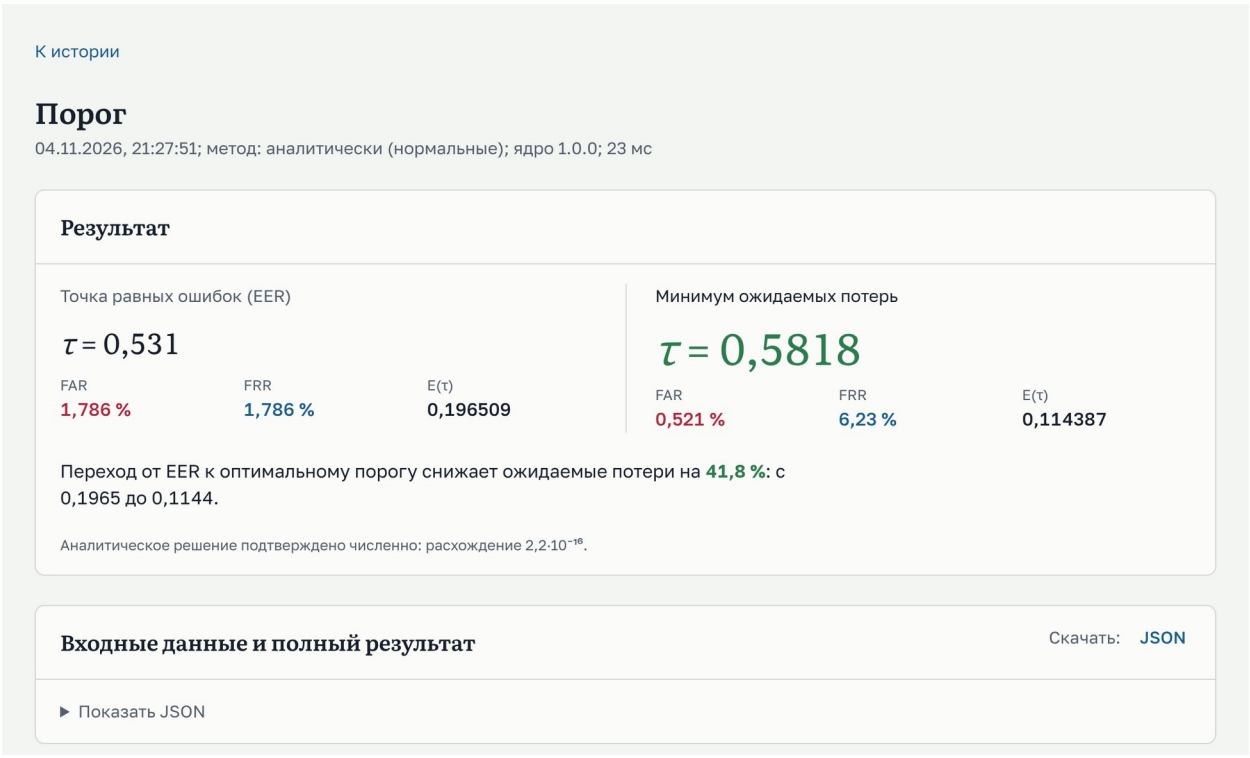


Рисунок 14 — Карточка эксперимента

Эксперименты неизменяемы: если позже изменить каталог факторов, сохранённые результаты не изменятся.

7 ЭКСПОРТ РЕЗУЛЬТАТОВ

Над графиками результатов расположена строка **«Скачать:»**:

Таблица 8 — Форматы экспорта

Формат	Содержимое	Применение
JSON	Входные данные и полный результат расчёта	Архив, повторный расчёт, обработка в Python или Excel (Power Query)
CSV	Точки графика (порог: τ, FAR, FRR, E) или рейтинг наборов (набор, FAR, FRR, задержка, стоимость, E)	Таблицы и графики в Excel, статьи
PNG графика	Изображение графика в высоком разрешении	Отчёты, презентации

8 РЕГИСТРАЦИЯ И ВХОД ПО ЛИЦУ

Этот раздел — для участника (субъекта), который входит в систему по лицу. Изображения лица не сохраняются: сервер превращает кадры в числовой шаблон, шифрует его и сразу удаляет кадры.

8.1 Регистрация

1) Откройте раздел **«Регистрация»**, введите логин (латинские буквы и цифры) и имя, нажмите **«Создать учётную запись»** (рисунок 15).
2) Прочитайте текст согласия на обработку биометрических данных, отметьте «Я прочитал(а) текст и даю согласие» и нажмите **«Дать согласие»**. Без согласия лицо не регистрируется.
3) Нажмите **«Включить камеру»** и разрешите браузеру доступ к ней. Совместите лицо с контуром головы: смотрите прямо, лицо должно быть хорошо освещено, без сильной тени и бликов (рисунок 16).
4) Нажмите **«Снять лицо»**: съёмка начнётся сама, когда лицо совпадёт с контуром (контур станет зелёным), и программа снимет 5 кадров. Если кадры не подошли, появятся подсказки («Лицо слишком далеко», «Слишком темно», «В кадре несколько лиц» и т. п.) — исправьте условия и повторите.
5) Последний шаг — **«Зарегистрировать passkey»**: браузер попросит подтвердить действие отпечатком пальца, Face ID или PIN-кодом устройства. Passkey нужен, если политика входа требует второй шаг.

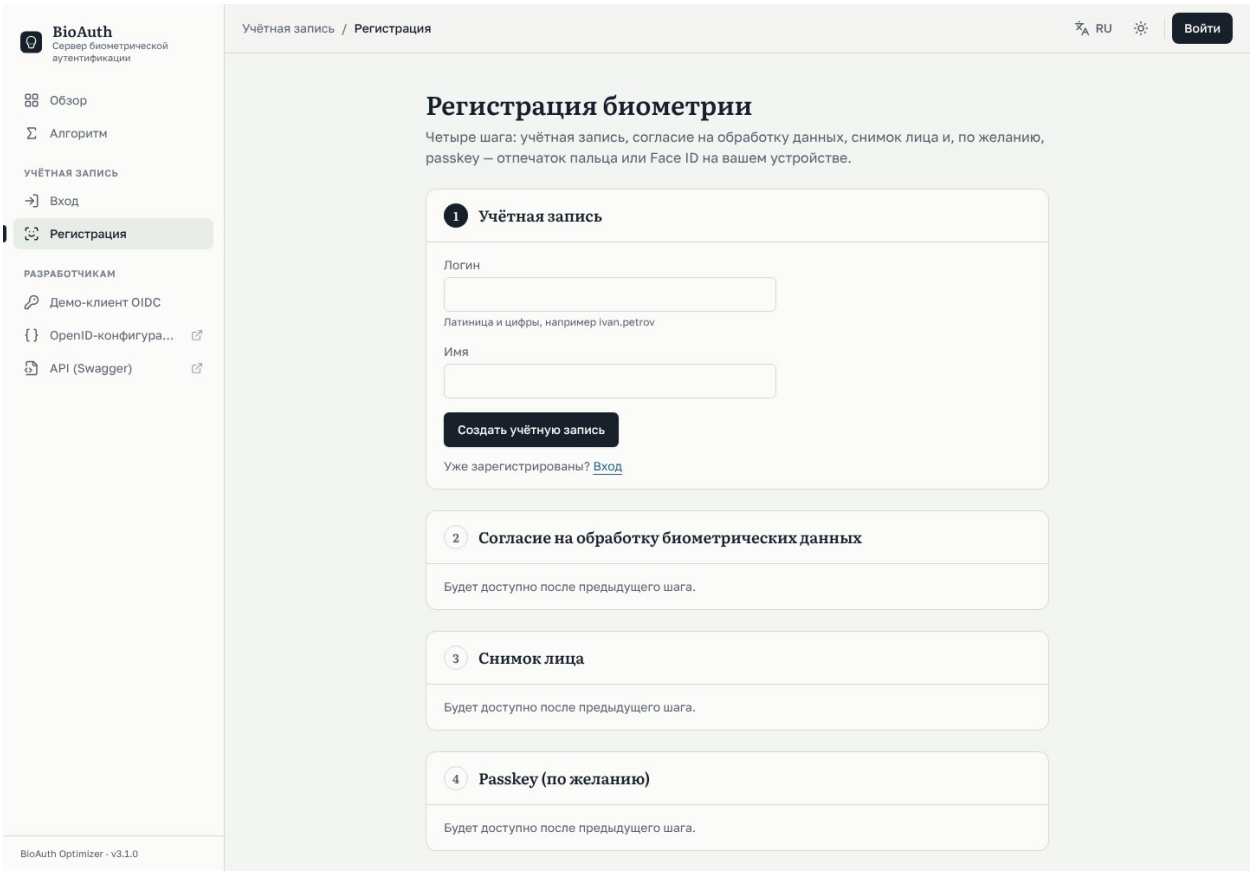


Рисунок 15 — Регистрация: учётная запись

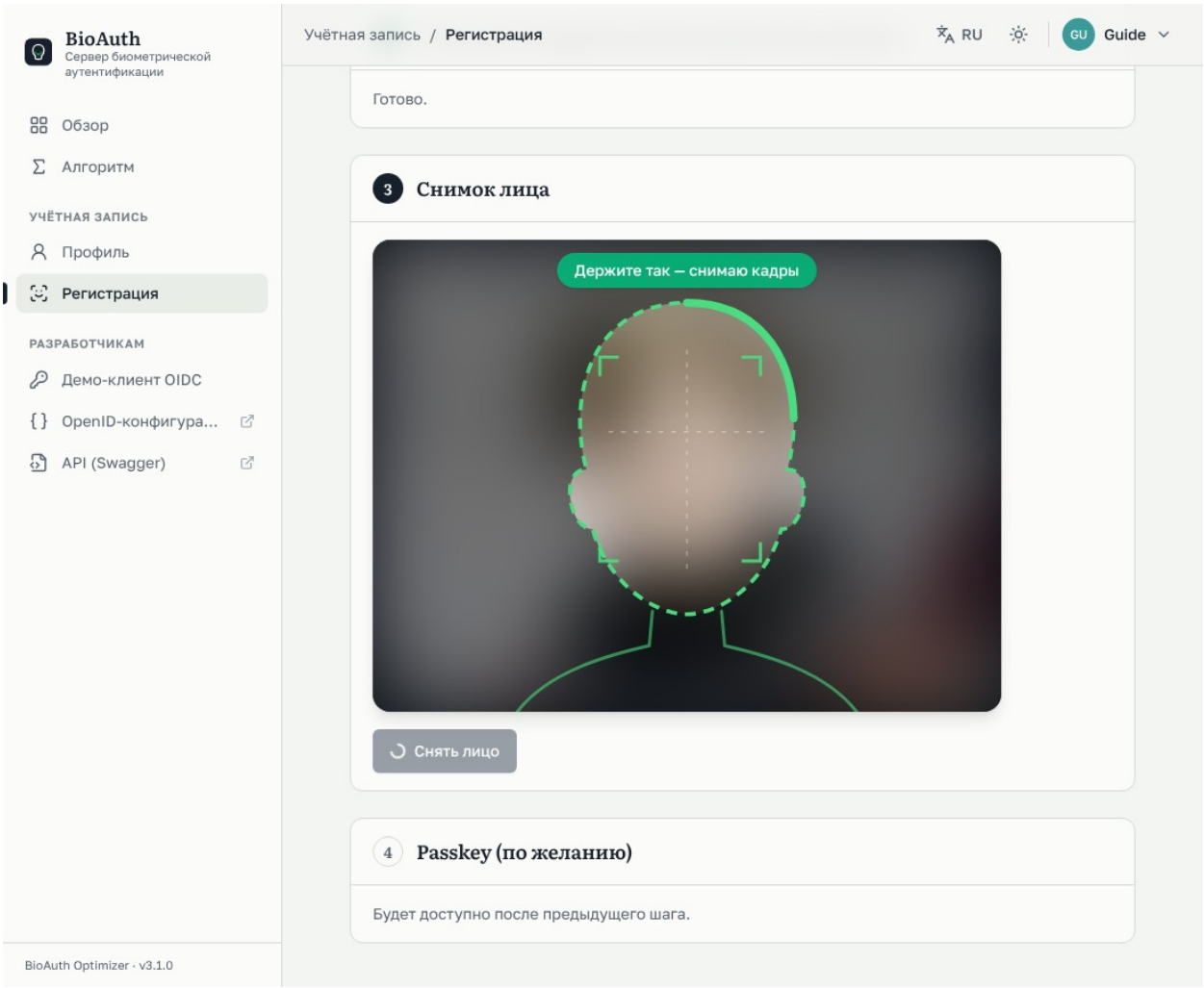


Рисунок 16 — Регистрация лица: контур головы и подсказка (лицо на снимке размыто)

8.2 Вход

1) Откройте **«Вход»** → вкладка **«По биометрии»**, введите логин и нажмите **«Продолжить»**. Программа покажет шаги действующей политики и случайные команды, например «поверните голову влево, поднимите подбородок, приблизьтесь к камере».
2) Включите камеру и нажмите **«Начать проверку»**. Сначала совместите лицо с контуром и посмотрите прямо, затем выполняйте команды: над контуром появляется подсказка, а стрелки и рамки показывают, куда двигать голову; полоса внизу и подсветка контура показывают, насколько движение уже выполнено (рисунок 17). На каждую команду даётся несколько секунд.

3) Если политика требует второй шаг, после сообщения «Лицо подтверждено» нажмите **«Подтвердить passkey»**.

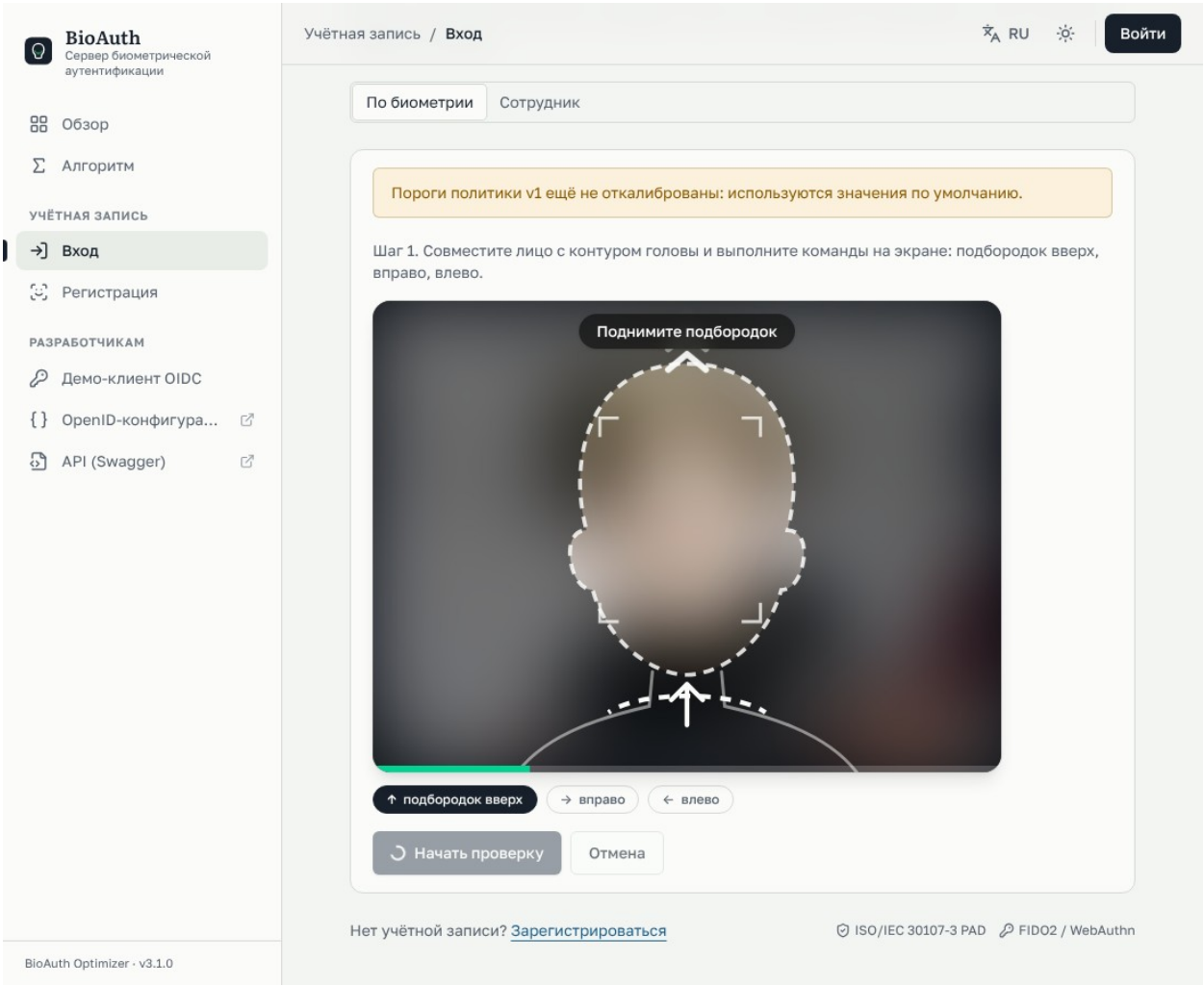


Рисунок 17 — Вход: команда, стрелка и индикатор выполнения (лицо размыто)

Если проверка не прошла, программа называет причину и число оставшихся попыток (рисунок 18). После трёх неудач подряд вход блокируется на 15 минут — это защита от подбора. Фотография или видео на экране не пройдут: они не выполняют команды и распознаются моделью «живости».

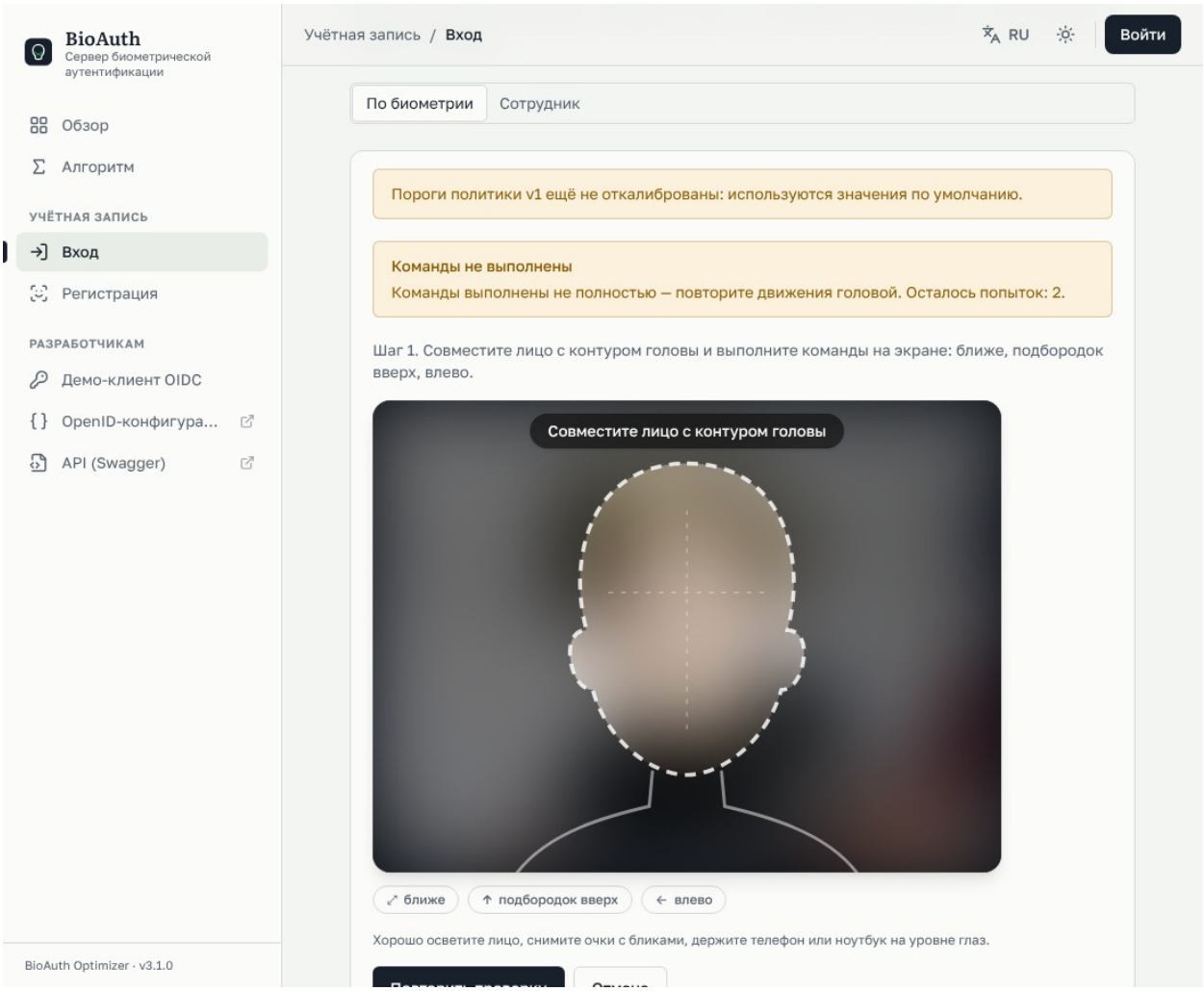


Рисунок 18 — Отказ: команды не выполнены

Таблица 9 — Причины отказа при входе

Сообщение	Что сделать
Лицо плохо видно	Улучшите освещение, приблизьтесь, уберите посторонних из кадра
Команды не выполнены	Выполняйте движения головой заметнее и не торопитесь
Проверка «живости» не пройдена	Убедитесь, что перед камерой вы, а не изображение; уберите блики
Лицо не совпало	Проверьте логин; при изменении внешности зарегистрируйте лицо заново
В кадре сменился человек	В кадре должен оставаться один и тот же человек
Вход заблокирован	Подождите 15 минут
Время истекло	Начните вход заново: на проверку отводится ограниченное время

8.3 Профиль

Профиль открывается из меню учётной записи (фото в правом верхнем углу) или пунктом «Профиль» в боковой панели (рисунок 19). В карточке — фото, имя, логин, роль, почта, дата регистрации и последнего входа, а также показатели: факторы входа, активные сессии, число успешных входов и подключённых приложений. Ниже — четыре вкладки.

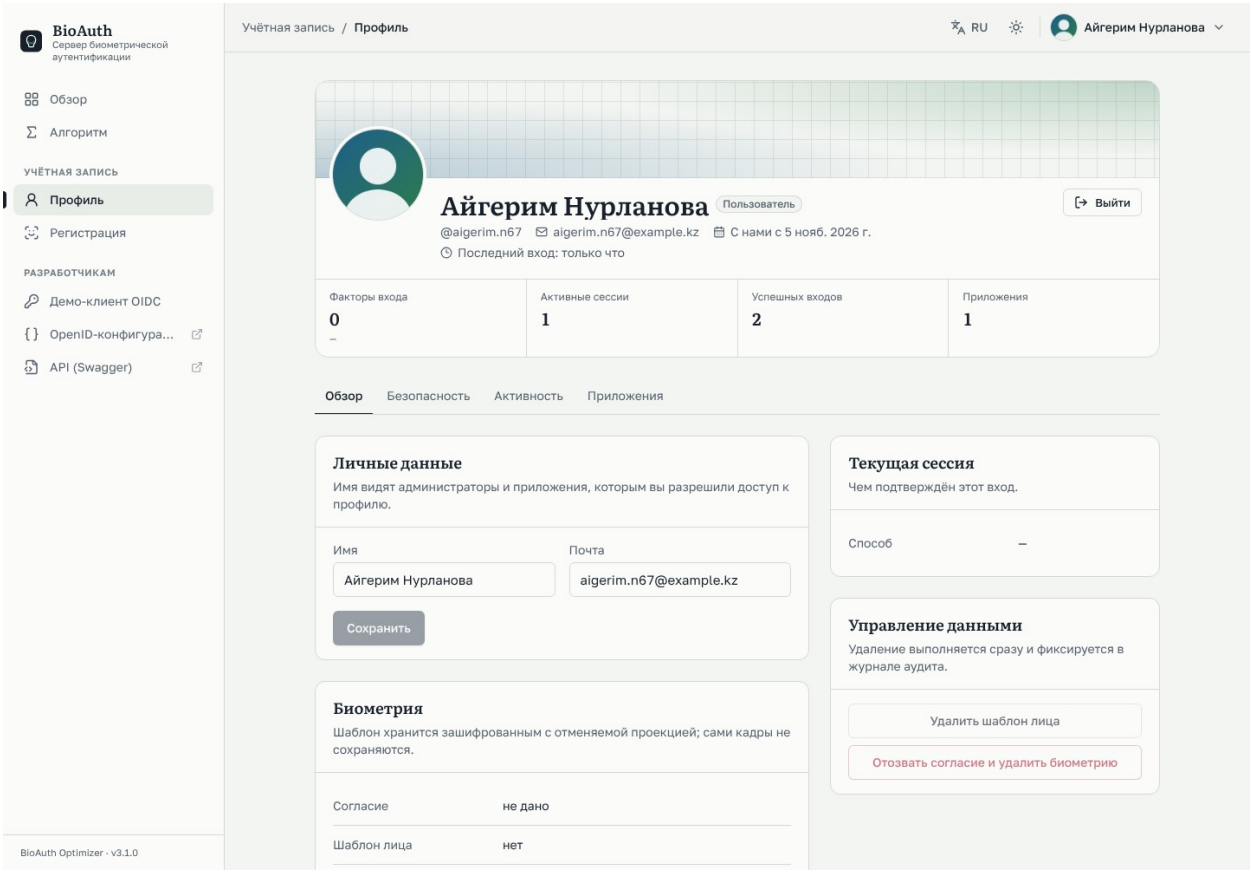


Рисунок 19 — Профиль пользователя

– **Обзор** — имя и почта (кнопка «Сохранить»), чем подтверждён текущий вход, состояние согласия, шаблона лица и passkey, управление данными;
– **Безопасность** — регистрация passkey и список **сессий и устройств**: браузер, система, IP-адрес, время входа и последней активности; кнопка «Завершить» закрывает чужую сессию, «Завершить все остальные» — все, кроме текущей (рисунок 21);
– **Активность** — история входов: успешные входы и отказы с причиной, способом входа, устройством и приложением;

– **Приложения** — сторонние приложения, которым вы разрешили вход через BioAuth; кнопка «Отключить» отзывает разрешение (раздел 10).

Фото профиля

Нажмите на фото в карточке профиля. Выберите **«Загрузить файл»** (PNG, JPEG или WebP) или **«Сделать фото»** — откроется камера, кнопка «Снять» делает снимок. Фото обрезается до квадрата; проверьте его в предпросмотре и нажмите **«Использовать»**. Кнопка «Удалить фото» возвращает инициалы.

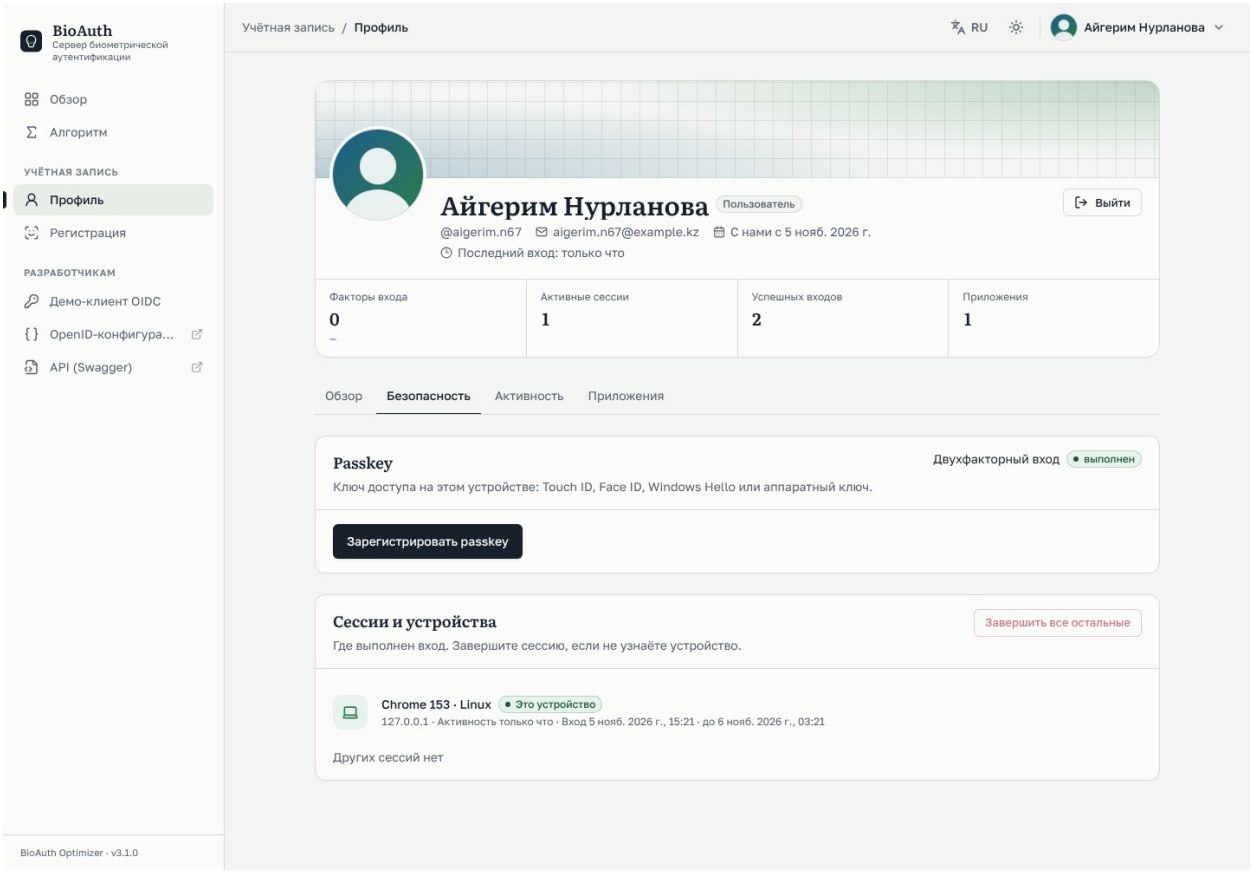


Рисунок 20 — Сессии и устройства

Удаление биометрических данных

На вкладке «Обзор» кнопка **«Удалить шаблон лица»** удаляет только шаблон; **«Отозвать согласие и удалить биометрию»** удаляет шаблон и passkey, а оценки обезличивает. Оба действия выполняются сразу и записываются в журнал аудита.

9 АДМИНИСТРИРОВАНИЕ

Для сотрудников в боковой панели появляется группа **«Администрирование»** (сводка, пользователи, журнал входов, политики, попытки, приложения OAuth, аудит), а на странице «Алгоритм» — вкладки калибровки и испытаний. Права зависят от роли:

Таблица 10 — Роли сотрудников

Роль	Что может
Администратор безопасности	Всё: калибровка, предложение и утверждение политик, испытание PAD, пакетный режим, журнал аудита
Исследователь	Калибровка, предложение политик, испытание PAD, пакетный режим; не утверждает политики
Аудитор	Только просмотр: обзор, политики, журнал попыток без оценок и логинов, протокол, журнал аудита

9.1 Вход сотрудника

На странице **«Вход»** выберите вкладку **«Сотрудник»**, введите логин и пароль (рисунок 21). Первый администратор создаётся при запуске (логин admin, пароль задаётся в настройках), остальных сотрудников создаёт администратор в разделе «Пользователи» (раздел 9.3) или команда, описанная в README. Изменения в админ-панели требуют двухфакторного входа: после пароля подтвердите вход passkey (при первом входе программа откроет «Профиль → Безопасность», где passkey регистрируется). Пока второй фактор не подтверждён, вверху страниц висит предупреждение.

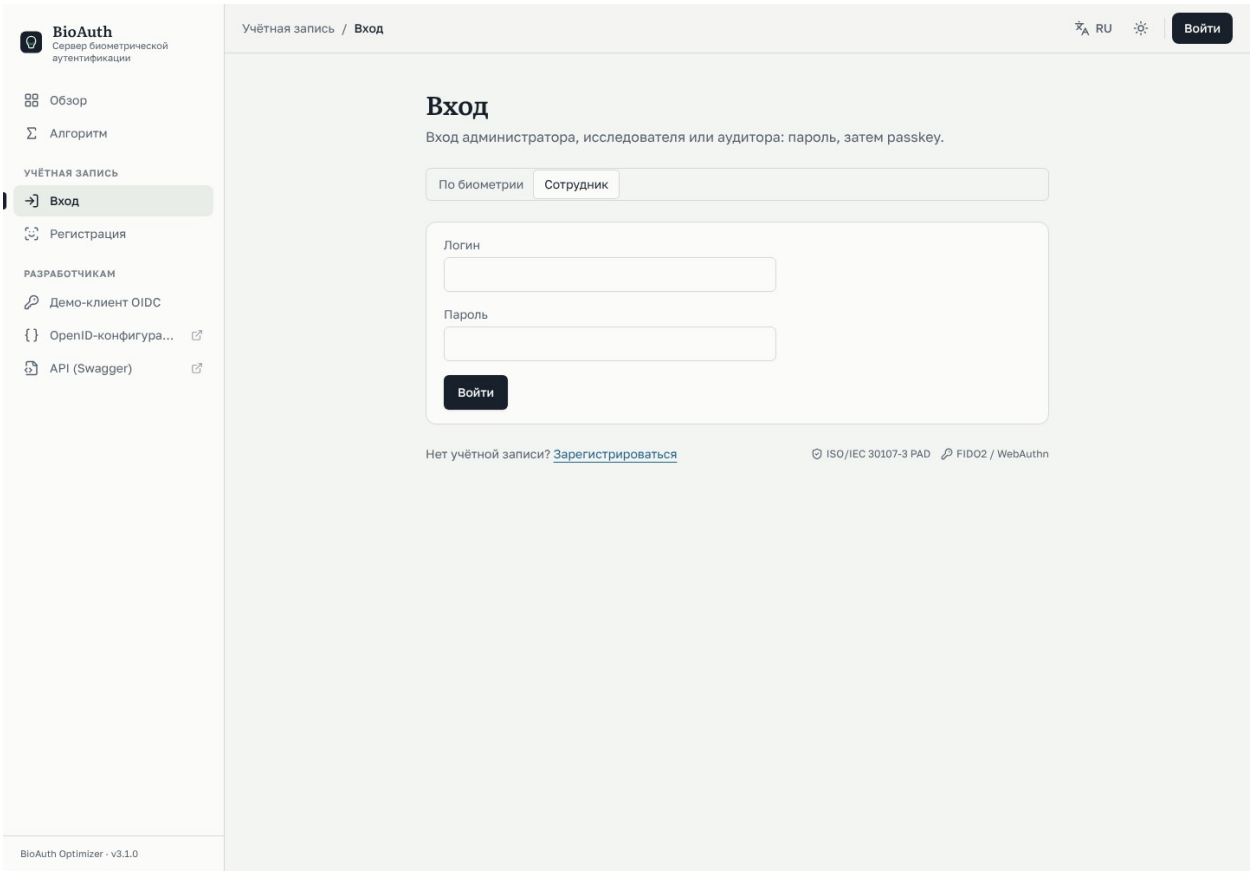


Рисунок 21 — Вход сотрудника

9.2 Сводка

Раздел **«Администрирование → Сводка»** показывает число пользователей (с лицом и с passkey), активные сессии, входы за 24 часа и отказы, приложения OAuth, график входов за 14 дней, способы входа, причины отказов, роли, действующую политику и последние входы; данные обновляются каждые 30 секунд (рисунок 22).

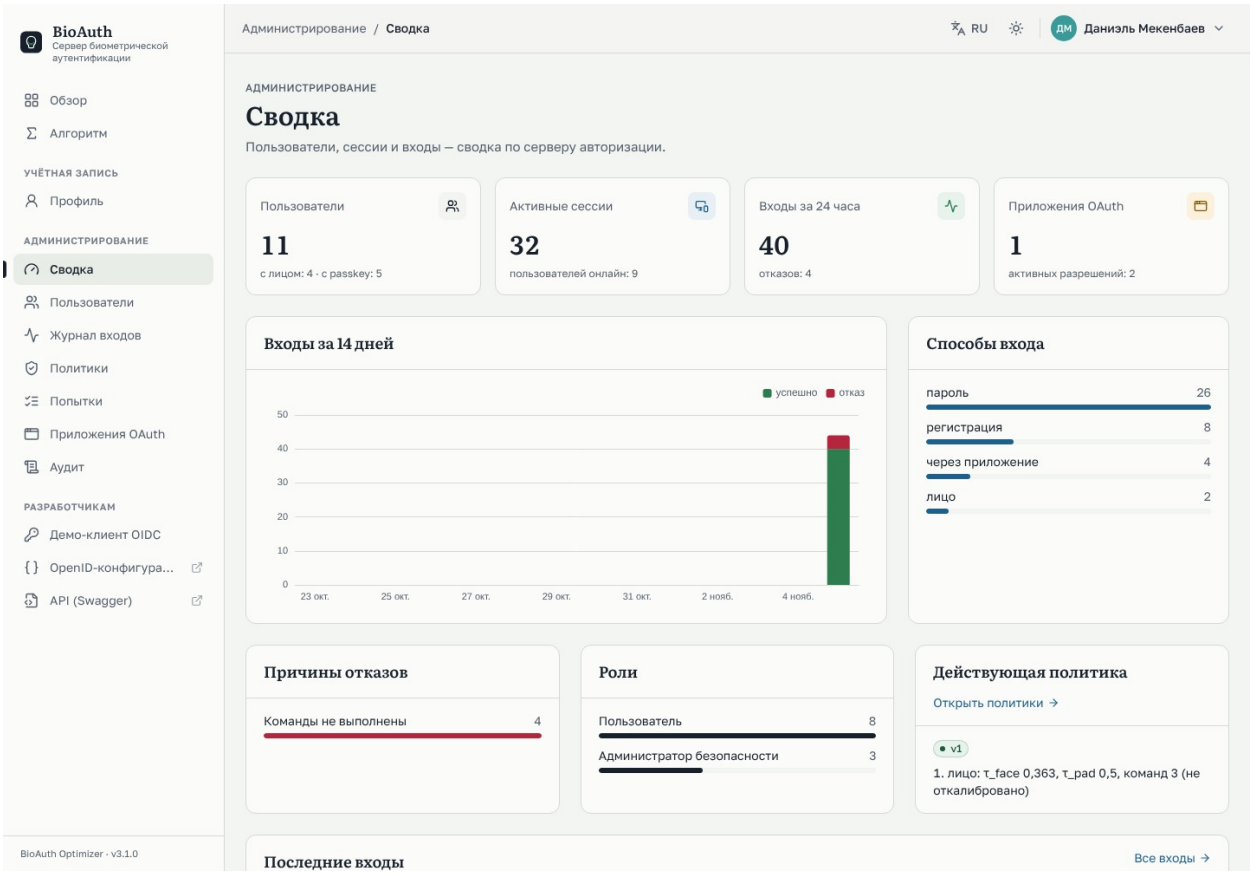


Рисунок 22 — Админ-панель: сводка

9.3 Пользователи и журнал входов

В разделе **«Пользователи»** есть поиск по логину, имени и почте и фильтры по роли и статусу (активен, заблокирован, отключён). Щелчок по строке открывает карточку пользователя: сессии, история входов и разрешения приложениям (рисунок 23). Администратор может изменить роль, **отключить** учётную запись (вход становится невозможен, сессии завершаются, токены приложений отзываются), снять блокировку после неудачных попыток и завершить все сессии. Свою роль и доступ, а также последнего администратора изменить нельзя. Кнопка **«Создать сотрудника»** создаёт исследователя, аудитора или администратора с временным паролем.

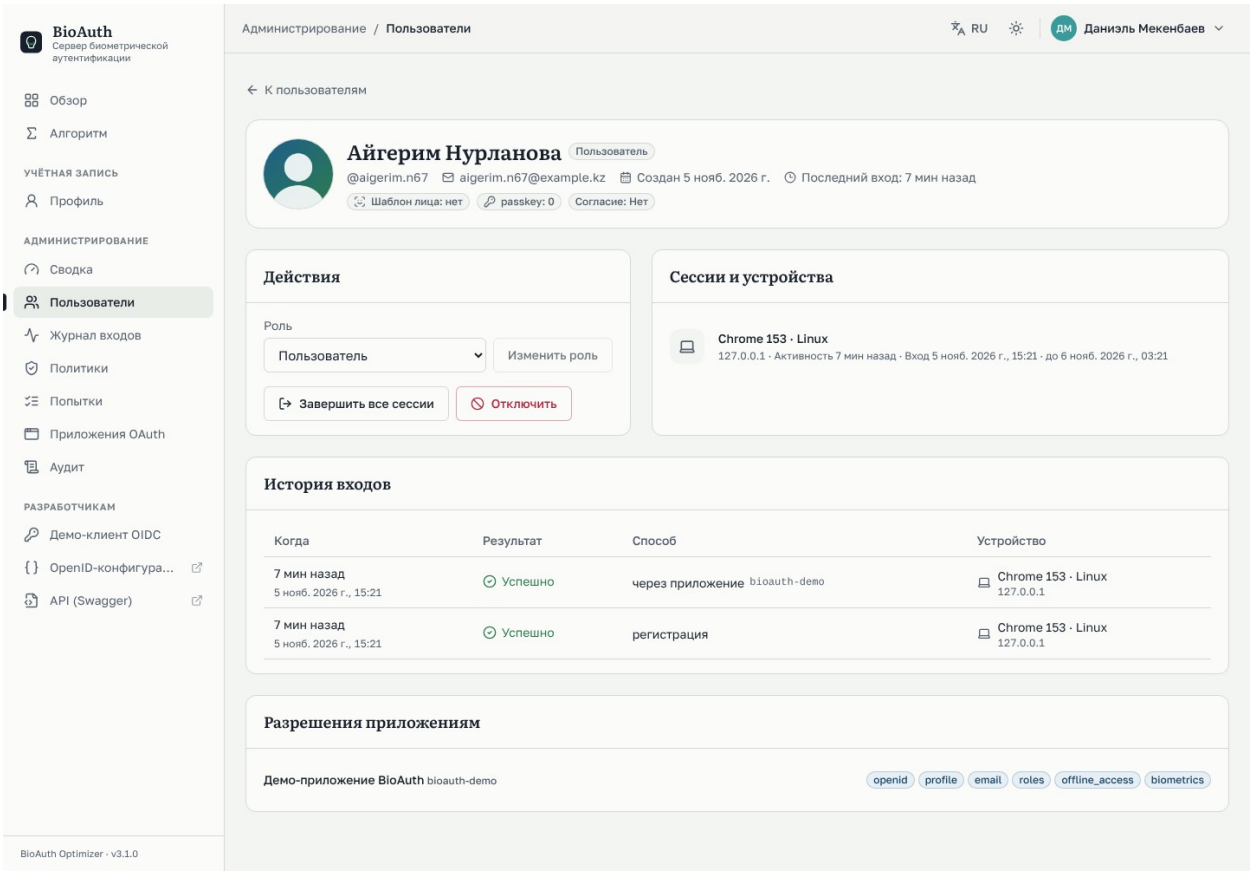


Рисунок 23 — Карточка пользователя

Раздел **«Журнал входов»** — входы и отказы всех пользователей, с переключателем «Только отказы».

9.4 Измерения

Вкладка **«Алгоритм → Измерения»** показывает действующую политику с порогами, версии, ожидающие решения, накопленные оценки по версиям моделей и измеренные характеристики факторов: FRR и время входа по журналу попыток, FAR passkey — заявленный (рисунок 24). Если доля ложных отказов за последнюю неделю заметно выросла, на всех вкладках появляется жёлтое уведомление о дрейфе — повод перекалибровать порог; администратор принимает его к сведению кнопкой в уведомлении.

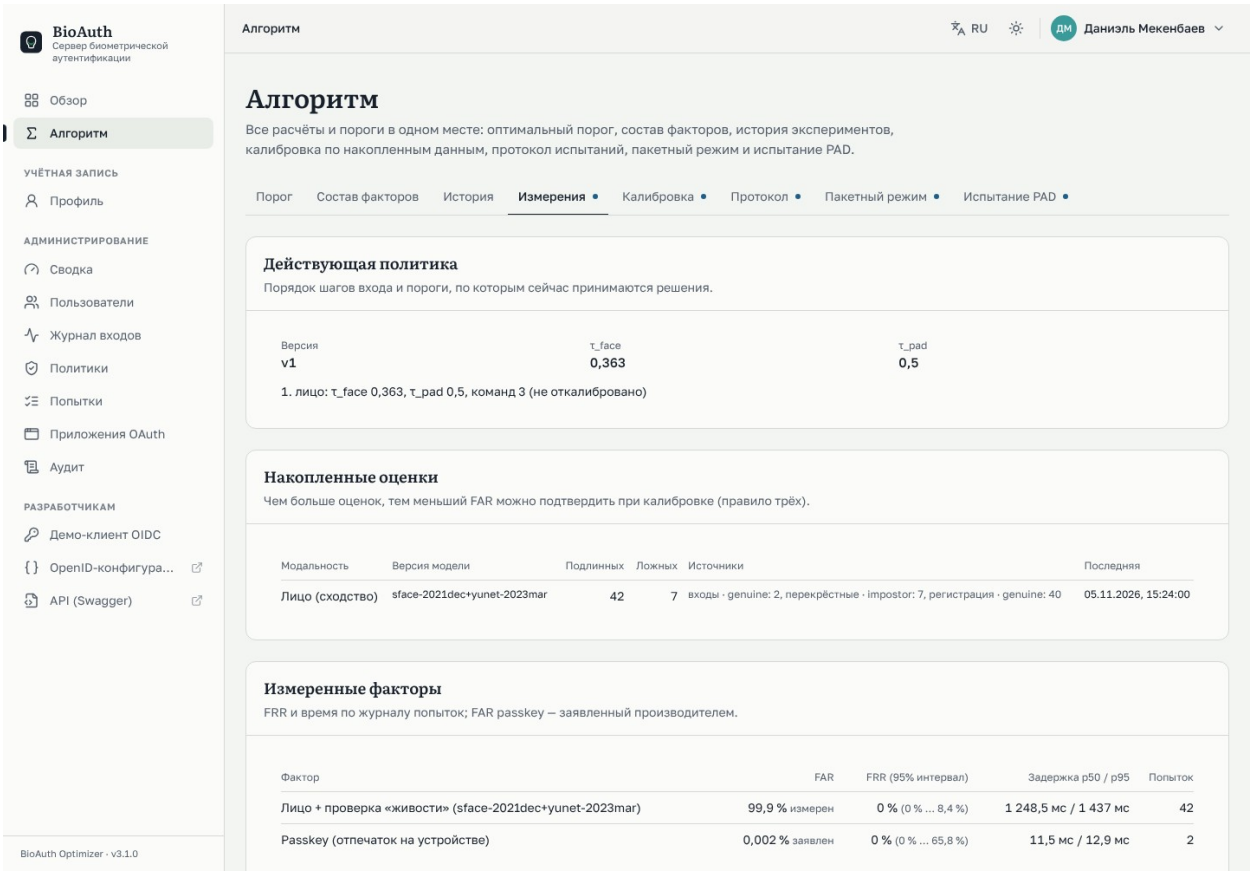


Рисунок 24 — Измерения: политика, накопленные оценки, измеренные факторы

9.5 Калибровка порога

1) На вкладке **«Алгоритм → Калибровка»** выберите, что калибровать: порог сходства τ_{face} или порог «живости» τ_{pad}, и версию модели. Оценки разных версий не смешиваются.
2) Задайте стоимости ошибок c_{FA}, c_{FR} и FAR, который нужно подтвердить данными, затем нажмите **«Рассчитать оптимальный порог»**.
3) Блок **«Достаточность данных»** показывает, какой FAR реально подтверждают накопленные оценки (правило трёх: для FAR ≤ p нужно не менее 3/p сравнений злоумышленников без ложных допусков) и сравнение с текущим порогом на тех же данных (рисунок 25). Ниже — те же графики, что в разделе 4.
4) Кнопка **«Предложить политику»** создаёт новую версию политики с найденным порогом. Она начнёт действовать только после утверждения (раздел 9.6).

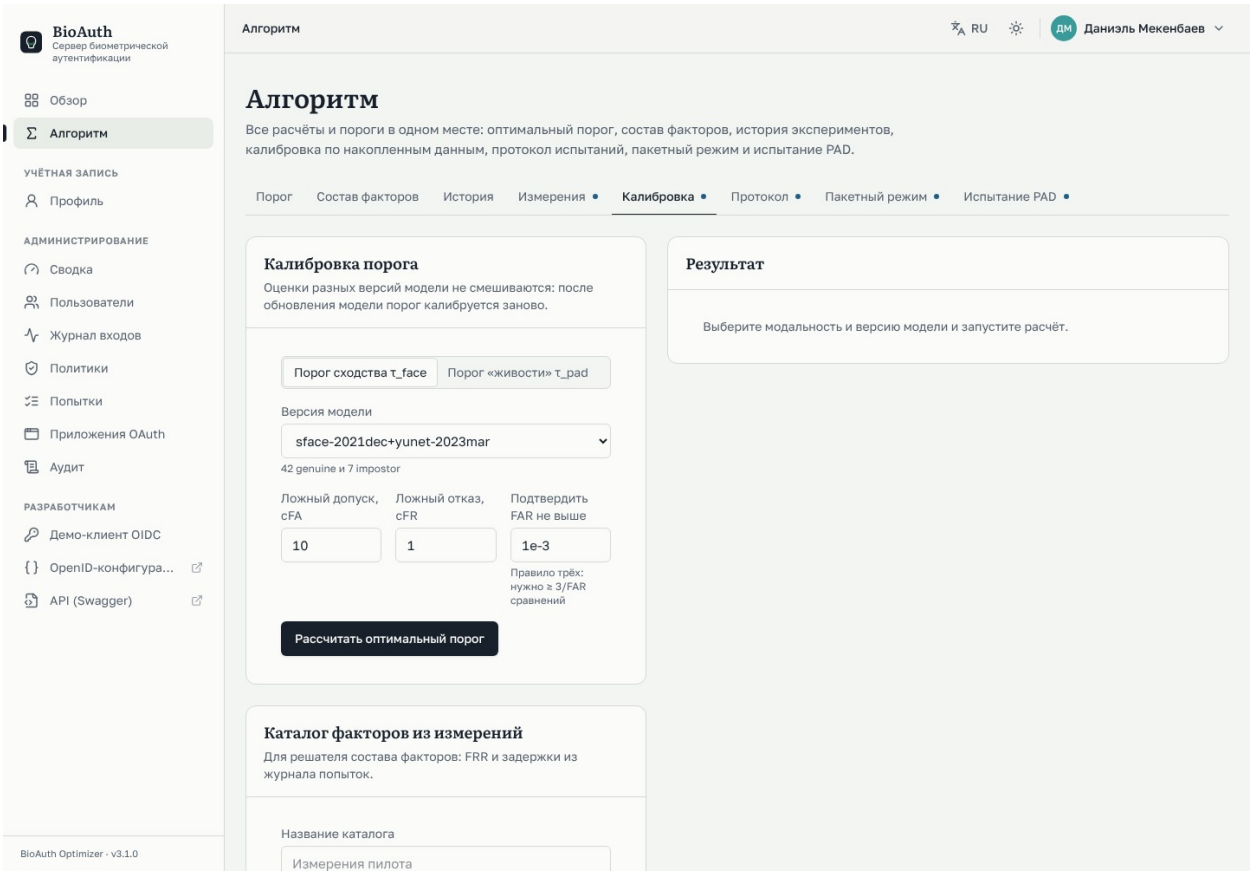


Рисунок 25 — Калибровка порога по накопленным оценкам

Кнопка **«Сохранить как каталог факторов»** на той же вкладке превращает измеренные характеристики в каталог для раздела «Состав факторов» — так выбор факторов опирается на измерения, а не на паспортные значения.

9.6 Политики

Раздел **«Политики»** — версии политики, новые сверху (рисунок 26). Предложенную версию администратор **утверждает** или **отклоняет** с комментарием; ранее действовавшую можно **вернуть**. Если администраторов несколько, предложение утверждает не его автор (принцип четырёх глаз). Справа — ручное предложение для испытаний: при числе команд меньше трёх программа напоминает, что правила биометрической проверки требуют не менее трёх случайных команд.

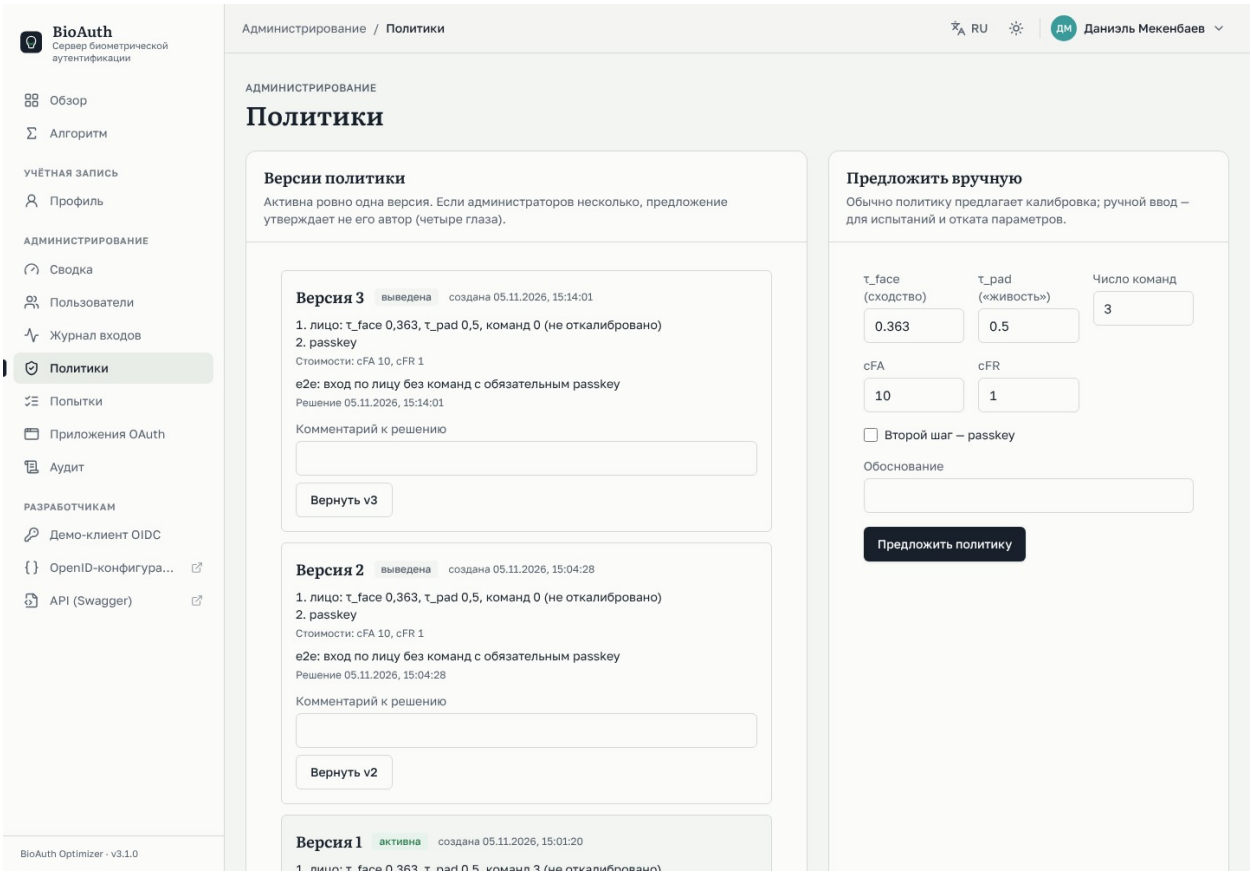


Рисунок 26 — Версии политики аутентификации

9.7 Журнал попыток

Раздел **«Попытки»** — все попытки входа с фильтрами по фактору и исходу, сводка по факторам (число попыток, доля отказов, 95-й процентиль времени, причины отказов) и подгрузка следующих страниц (рисунок 27). Изображения не хранятся — только решения, оценки и время. Аудитору оценки и логины не показываются.

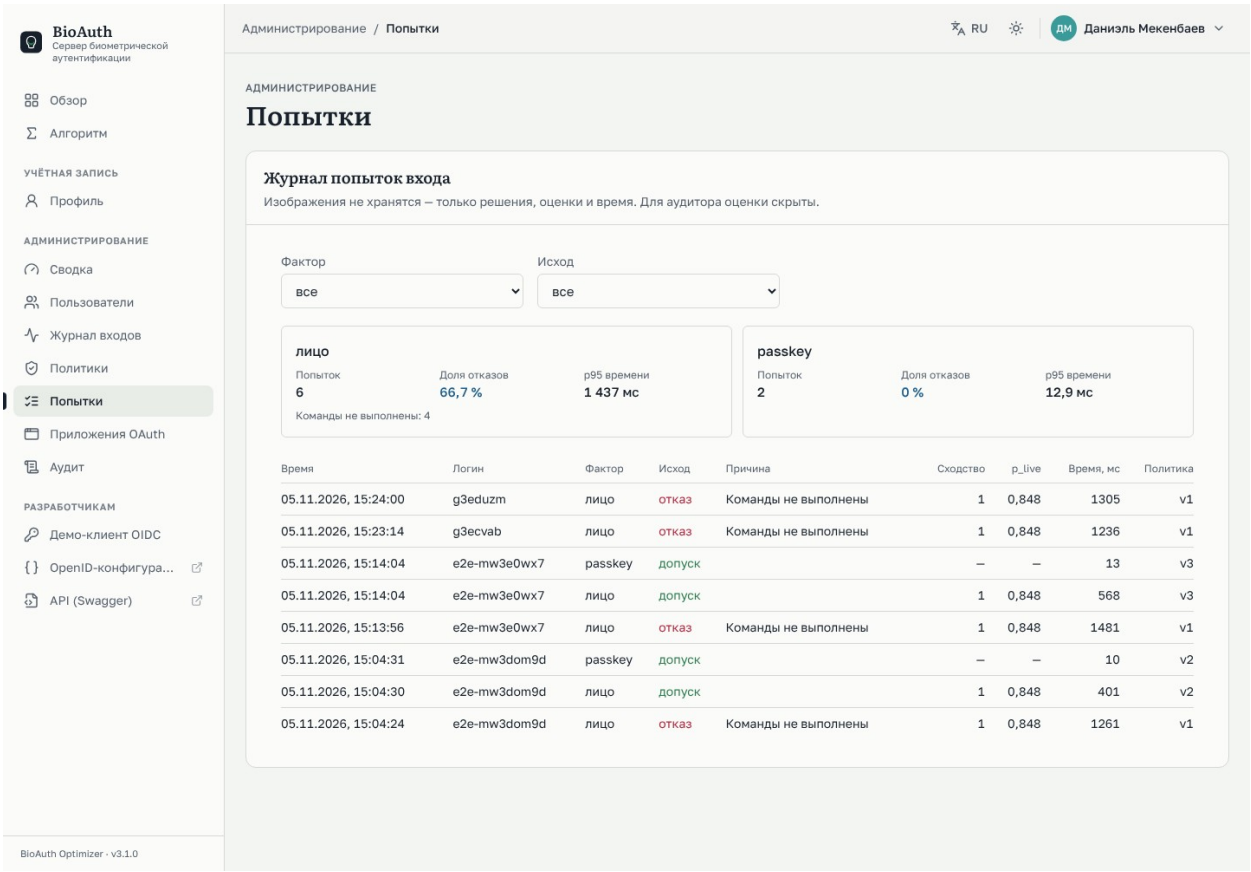


Рисунок 27 — Журнал попыток входа

9.8 Испытание защиты от атак (PAD)

На вкладке **«Алгоритм → Испытание PAD»** оператор выбирает, что предъявляется камере: живой участник или атака определённого вида (печатное фото, фото на экране, видео, маска), и нажимает **«Записать предъявление»**. Справа строится отчёт по ISO/IEC 30107-3: BPCER и APCER для каждого вида атаки с 95-процентными интервалами; порог для отчёта можно изменить (рисунок 28). Протокол испытания и форма согласия участника — в папке docs/protocol.

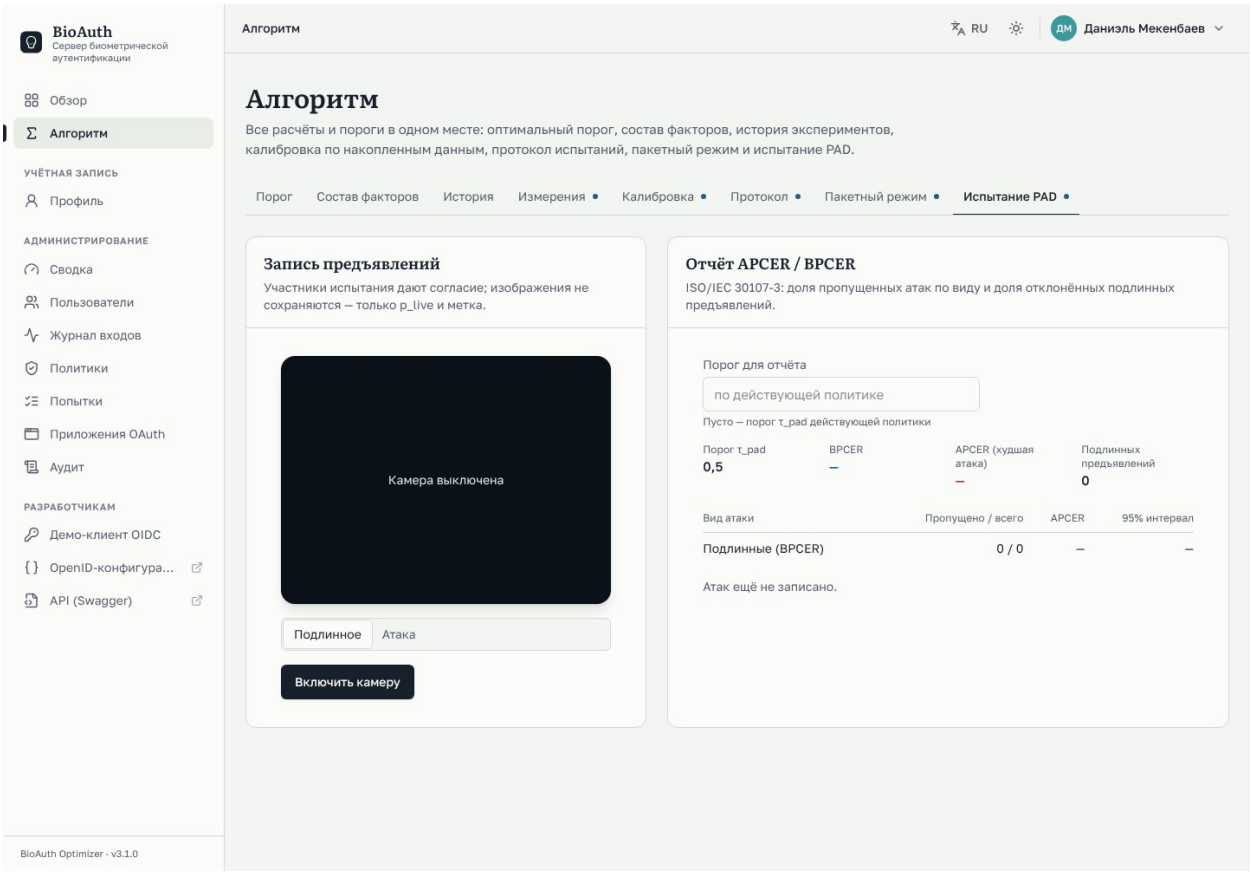


Рисунок 28 — Испытание PAD

9.9 Пакетный режим

Живых попыток мало, чтобы подтвердить FAR порядка 10^{-5}. Вкладка **«Алгоритм → Пакетный режим»** считает оценки по набору изображений: загрузите zip-архив, где у каждого человека своя папка (alice/1.jpg, alice/2.jpg, bob/1.jpg …), задайте seed и максимальное число пар злоумышленников и нажмите **«Запустить обработку»** (рисунок 29). Сравниваются все пары изображений одного человека и пары разных людей — полностью или случайной выборкой с seed, поэтому повторный запуск даёт тот же результат. Готовый набор оценок открывается в разделе «Порог» и скачивается в CSV; по флажку оценки добавляются в калибровку. Используйте только наборы, лицензия которых это разрешает.

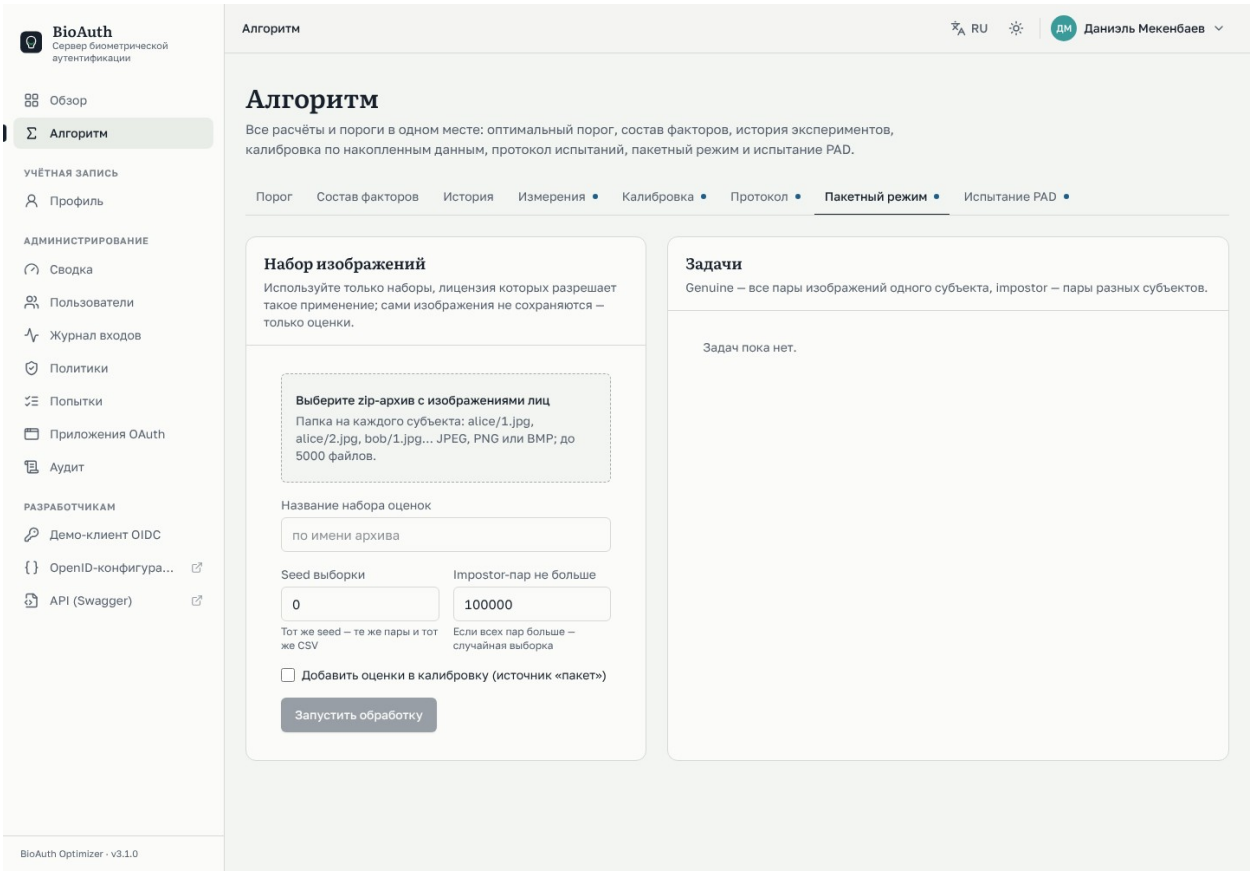


Рисунок 29 — Пакетный режим

9.10 Протокол «до/после калибровки»

Вкладка **«Алгоритм → Протокол»** сравнивает исходную и действующую политики на одних и тех же оценках: FAR и FRR с 95-процентными интервалами Уилсона, подтверждённый FAR, ожидаемые потери E, BPCER и наибольший APCER (рисунок 30). Меняется только порог, поэтому разница в E показывает эффект калибровки. Стоимости можно изменить, таблица выгружается в CSV для отчёта и статьи.

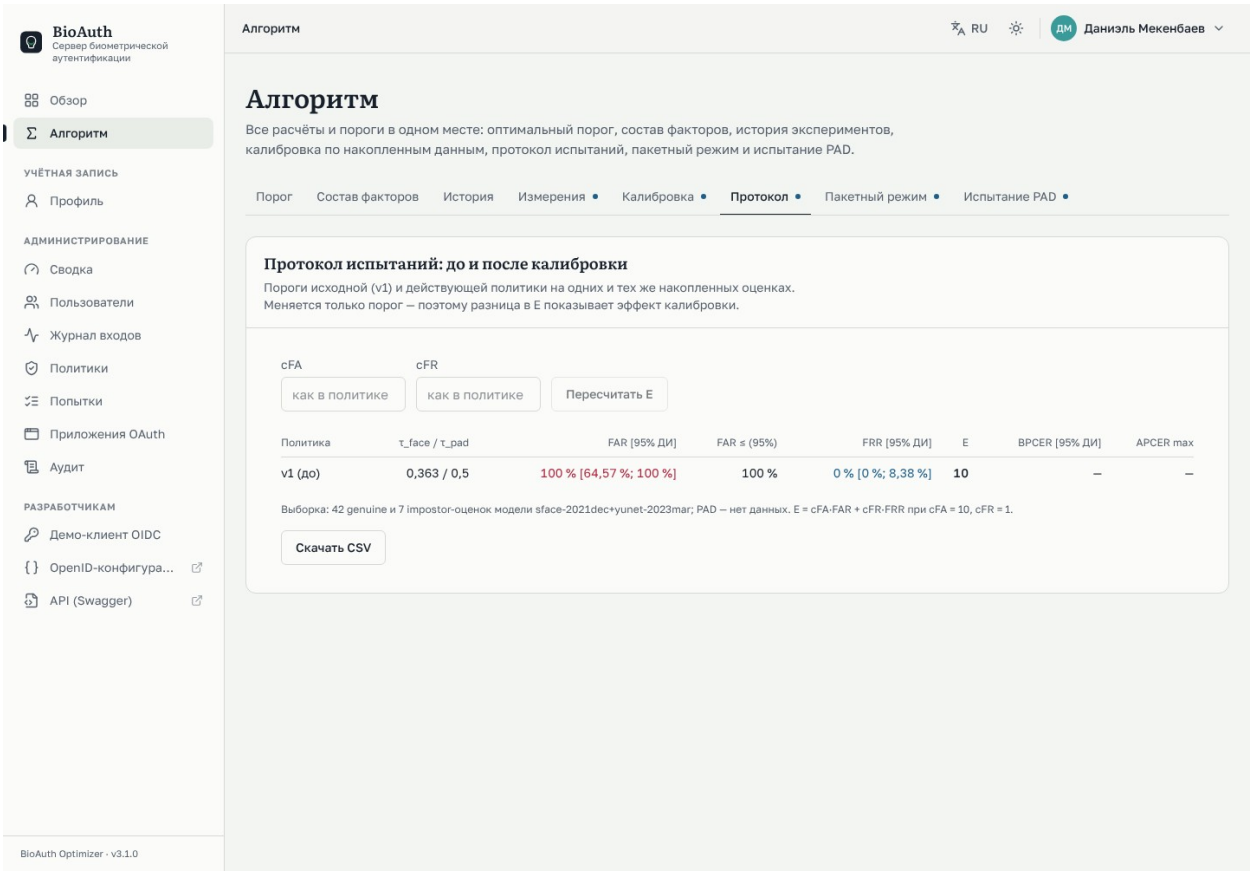


Рисунок 30 — Протокол испытаний

9.11 Журнал аудита

Раздел **«Аудит»** (администратор и аудитор) — кто, когда и что сделал: согласия, регистрация и удаление биометрии, решения по политикам, входы сотрудников, пакетные расчёты. Записи нельзя изменить или удалить, а каждая содержит хэш предыдущей; кнопка **«Проверить целостность»** пересчитывает цепочку и сообщает номер первой записи, если журнал правили в обход программы (рисунок 31).

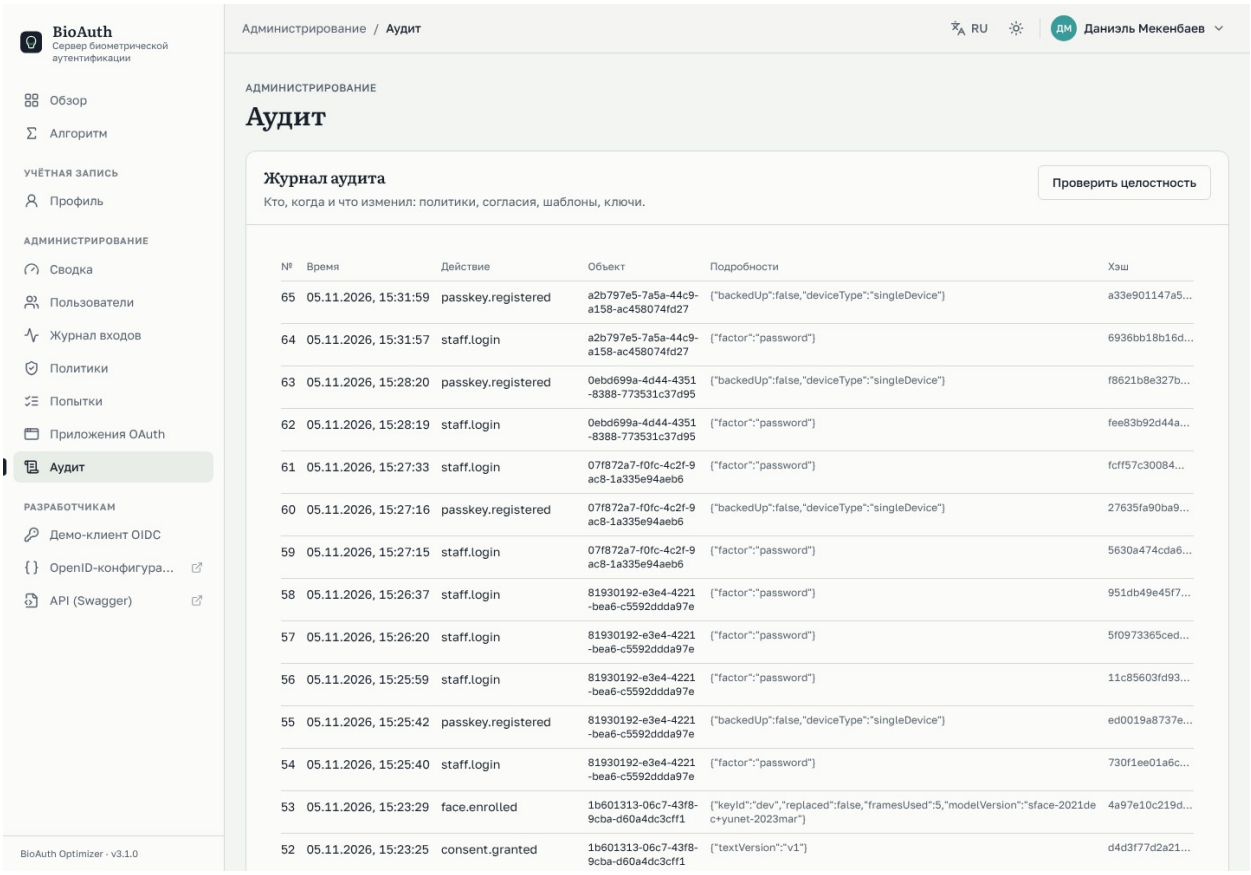


Рисунок 31 — Журнал аудита и проверка целостности

10 ВХОД В ДРУГИЕ ПРИЛОЖЕНИЯ ЧЕРЕЗ BIOAUTH (OPENID CONNECT)

BioAuth работает как **сервер авторизации**: другие сервисы организации (портал, CRM, мобильное приложение) могут предлагать кнопку «Войти через BioAuth». Пользователь проходит проверку лица и passkey в BioAuth, а приложение получает подтверждение личности и сведения профиля — но не изображения и не биометрический шаблон.

10.1 Как это выглядит для пользователя

1) В приложении нажмите «Войти через BioAuth» — откроется страница входа BioAuth с названием приложения.
2) Пройдите вход как обычно (раздел 8.2). Если вы уже вошли, этот шаг пропускается.
3) При первом входе в приложение появится **экран согласия** со списком данных, которые получит приложение (рисунок 32). Нажмите **«Разрешить»** или **«Отклонить»**. Решение запоминается; отозвать его можно в «Профиль → Приложения».
4) Вы вернётесь в приложение уже вошедшим.

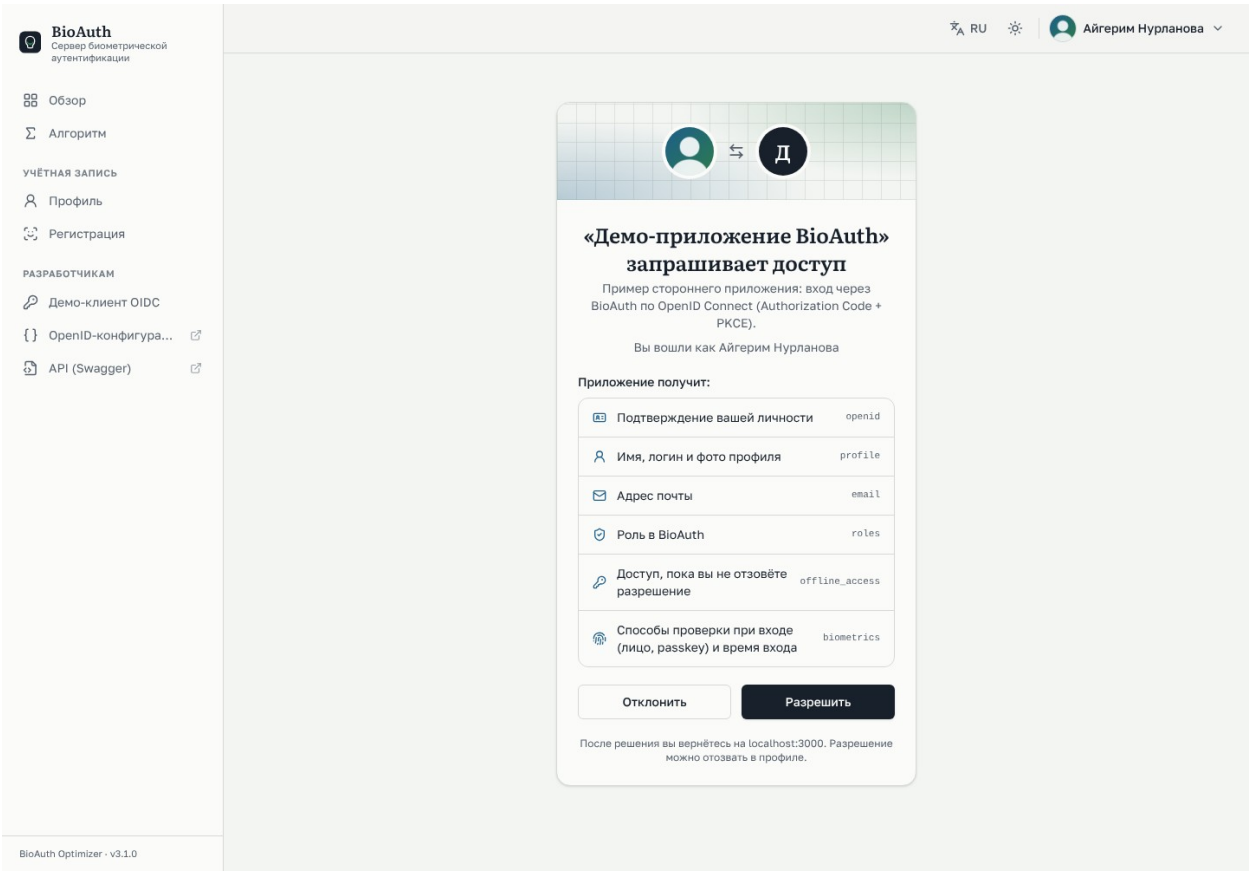


Рисунок 32 — Экран согласия на доступ приложения

Если приложение просит выйти, а BioAuth не может убедиться, что запрос пришёл от него, появится вопрос «Выйти из BioAuth?» — так посторонний сайт не может завершить вашу сессию ссылкой.

10.2 Демо-клиент

Раздел **«Разработчикам → Демо-клиент OIDC»** — встроенный пример стороннего приложения. Кнопка «Войти через BioAuth» проходит весь путь и показывает полученные данные: ID-токен с подписью RS256 и указанием способа входа (amr: лицо, passkey), токен доступа и ответ userinfo; кнопки позволяют обновить токены и выйти (рисунок 33).

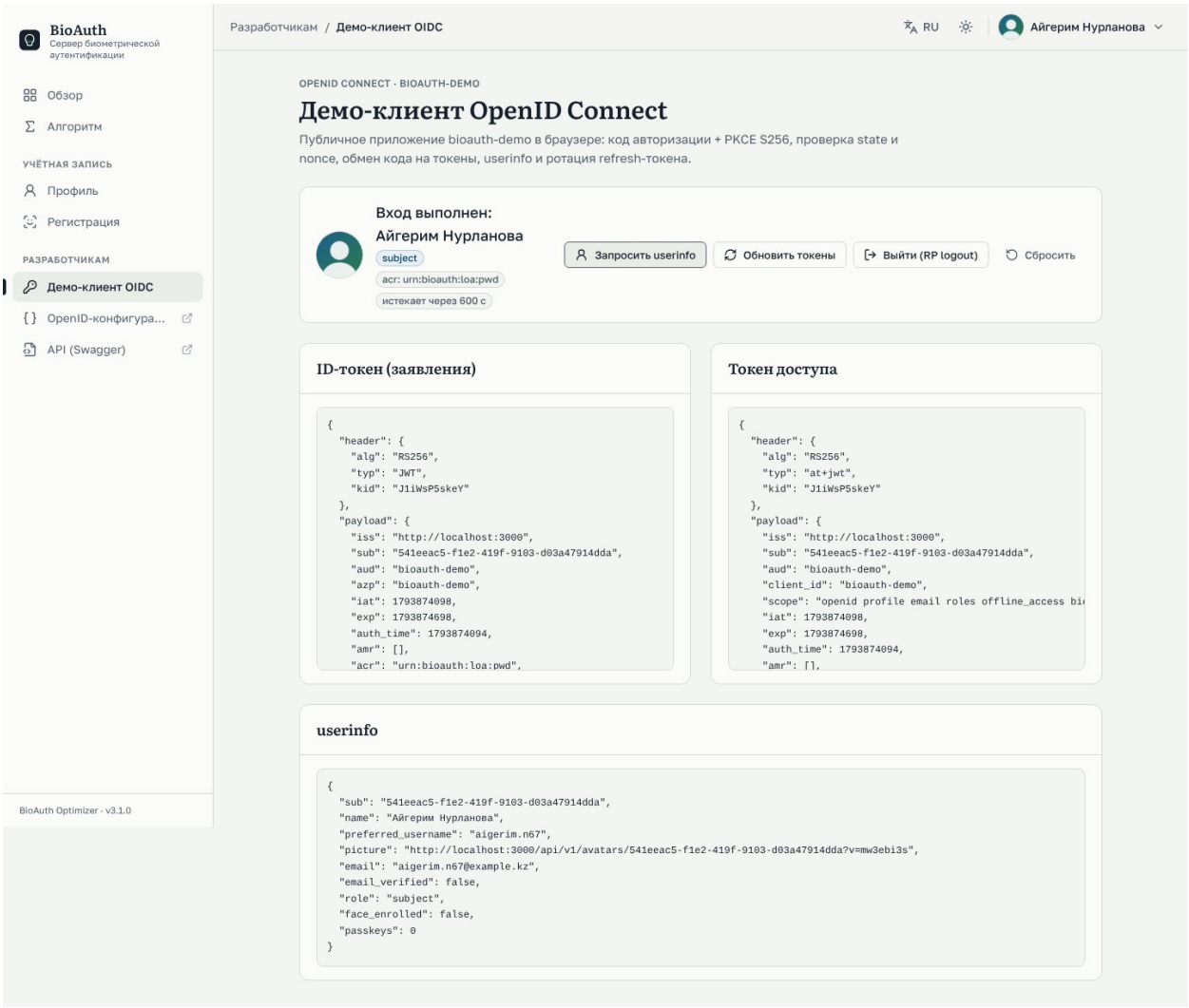


Рисунок 33 — Демо-клиент после входа

10.3 Подключение своего приложения (для администратора)

1) Откройте **«Администрирование → Приложения OAuth»** и нажмите **«Новое приложение»** (рисунок 34).
2) Укажите идентификатор (client_id), название и описание (их видит пользователь на экране согласия) и тип: **конфиденциальное** — серверное приложение с секретом, **публичное** — SPA или мобильное приложение без секрета, вход только с PKCE.
3) Перечислите адреса возврата по одному в строке (https, http — только для localhost), выберите типы разрешений и области доступа (scope): openid, profile, email, roles, offline_access, biometrics.
4) Нажмите «Создать». Для конфиденциального приложения **секрет показывается один раз** — скопируйте его в настройки приложения.

Позже можно выпустить новый секрет, отключить или удалить приложение.

5) Справа на странице — адреса сервера авторизации (issuer, authorize, token, userinfo, jwks); их указывают в любой стандартной библиотеке OpenID Connect.

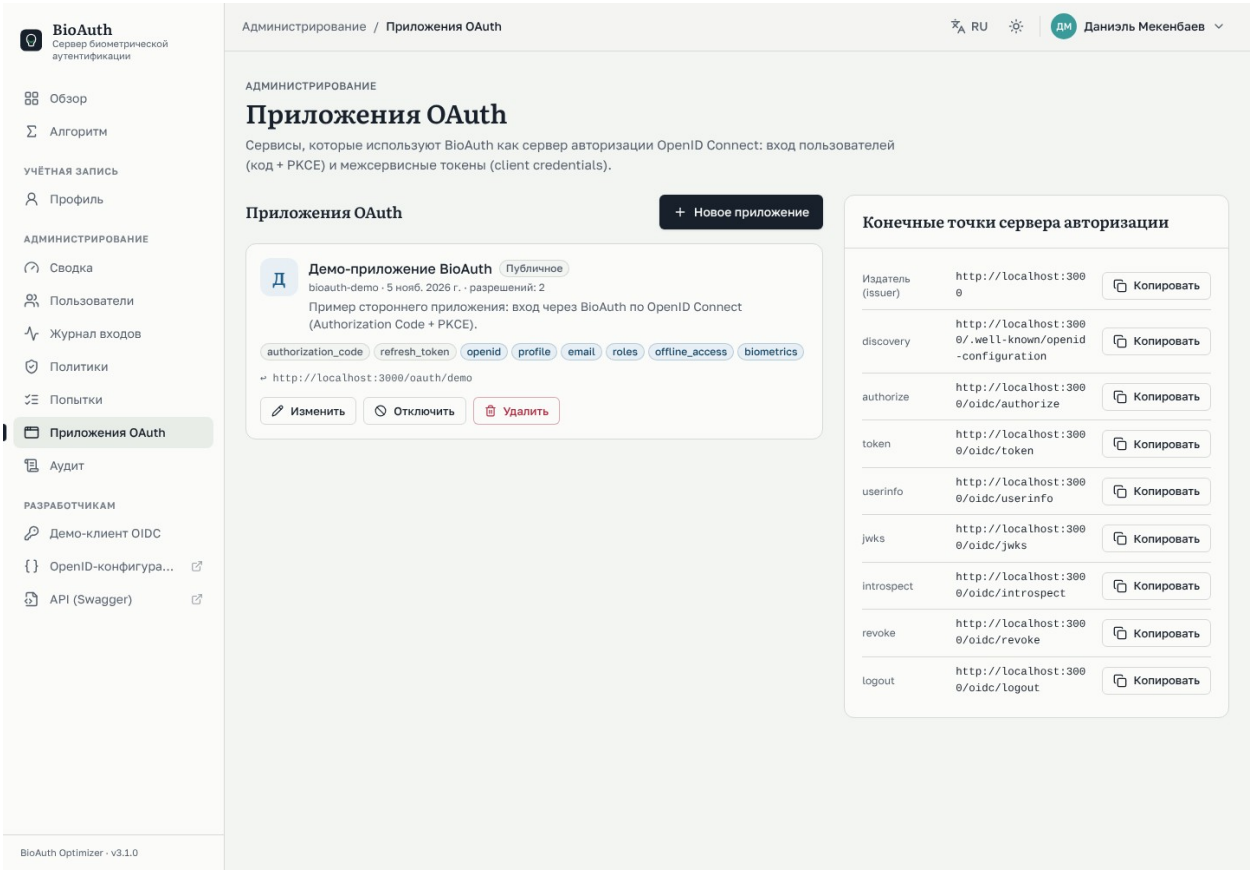


Рисунок 34 — Приложения OAuth и адреса сервера авторизации

11 ЯЗЫК, ТЕМА И УСТАНОВКА КАК ПРИЛОЖЕНИЕ

– **Язык** — кнопка с буквами RU/KZ/EN в верхней панели: русский, казахский или английский.
– **Тема** — кнопка с солнцем или луной: светлая, тёмная или как в системе (рисунок 35).
– **Телефон** — интерфейс подстраивается под ширину экрана: разделы открываются кнопкой меню, таблицы превращаются в карточки.
– **Установка** — в Chrome и Edge в боковой панели появляется кнопка **«Установить приложение»** (или значок установки в адресной строке); на iPhone — «Поделиться → На экран „Домой“». Установленное приложение открывается в отдельном окне со своим значком и ярлыками разделов. Без сети открываются уже посещённые страницы, но вход и расчёты требуют связи с сервером.

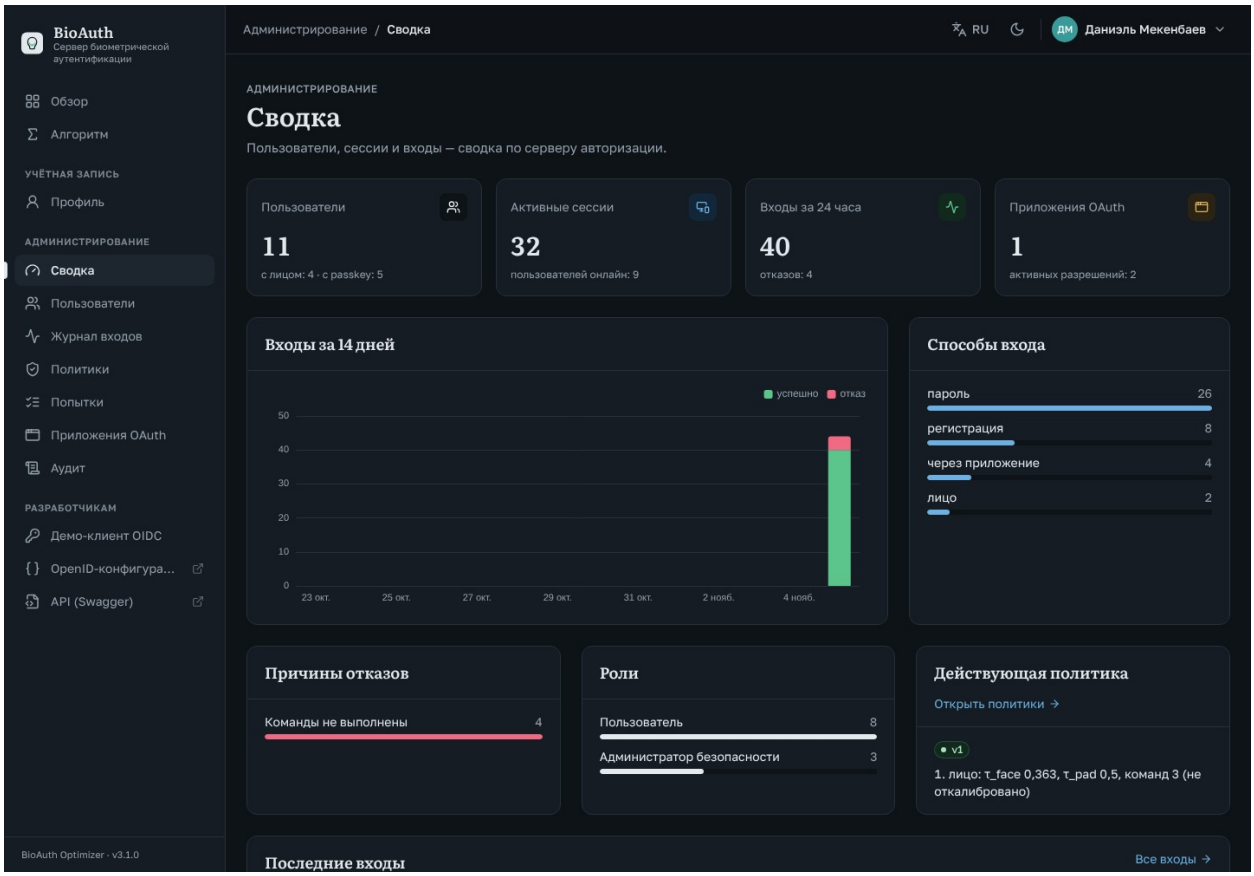


Рисунок 35 — Тёмная тема

12 ПРОГРАММНЫЙ ИНТЕРФЕЙС ДЛЯ ИНТЕГРАЦИИ

Все функции интерфейса доступны через REST API — например, чтобы пересчитывать порог из скрипта или другой системы. Справочник API (Scalar) с поиском, примерами запросов на curl, JavaScript, Python и других языках и возможностью выполнить запрос прямо из браузера открывается пунктом **«Разработчикам → Документация API (Scalar)»** или по адресу http://localhost:4000/api/docs (рисунок 36). Справочник работает и без интернета; спецификация OpenAPI для генераторов клиентов — http://localhost:4000/api/openapi.json.

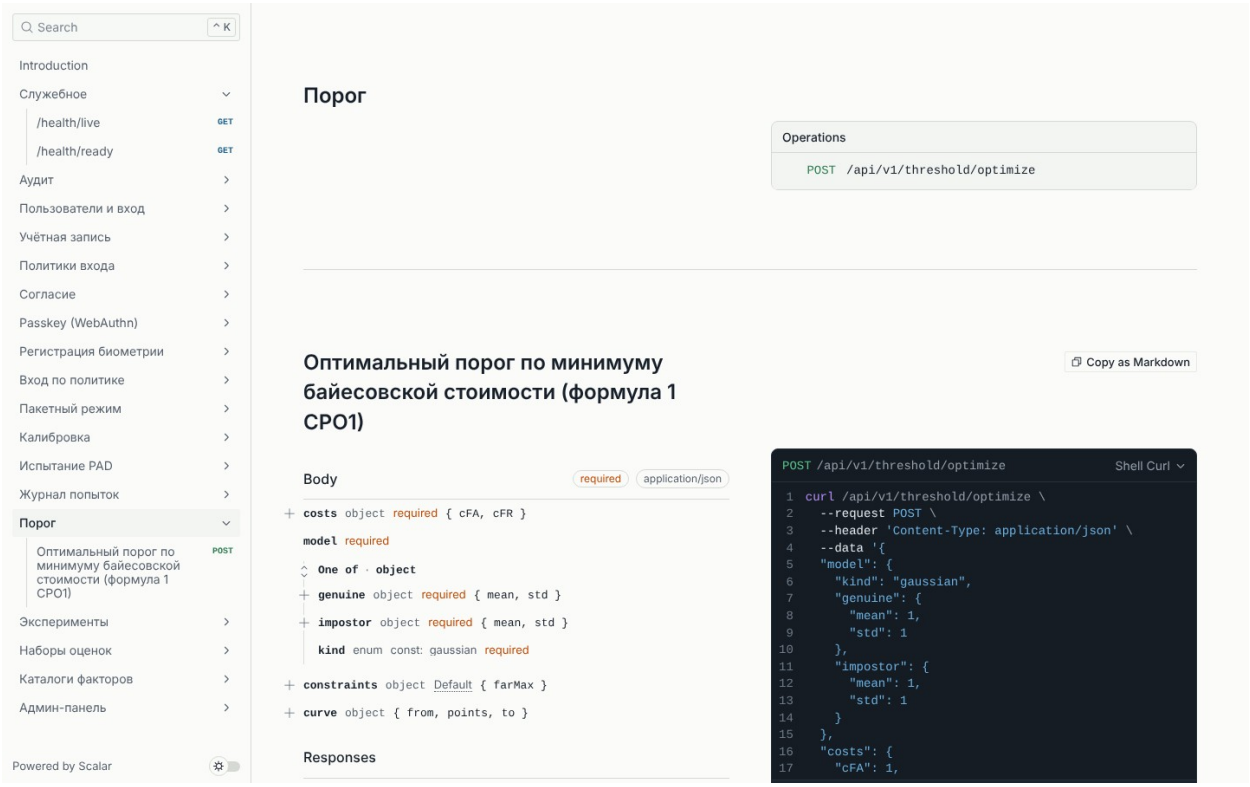


Рисунок 36 — Справочник API в Scalar

Пример: расчёт порога из командной строки.

```
curl -X POST http://localhost:4000/api/v1/threshold/optimize \
  -H "content-type: application/json" \
  -d '{"model":{"kind":"gaussian","genuine":{"mean":0.72,"std":0.09},
       "impostor":{"mean":0.3,"std":0.11}},"costs":{"cFA":10,"cFR":1},
       "constraints":{"farMax":null}}'
```

Ответ содержит порог EER и оптимальный порог с вероятностями ошибок, снижение потерь и идентификатор сохранённого эксперимента.

Ошибки возвращаются в стандартном формате RFC 7807 с понятным текстом на русском языке.

13 СООБЩЕНИЯ ОБ ОШИБКАХ

Таблица 11 — Сообщения программы и действия пользователя

Сообщение	Причина	Что делать
«Введите число» под полем	В поле не число	Введите число; дробную часть можно отделять запятой или точкой
«среднее законных пользователей должно быть больше среднего злоумышленников»	$\mu_G \le \mu_I$	Проверьте, не перепутаны ли группы
«Некорректные входные данные»	Значение вне допустимого диапазона (например, $\sigma \le 0$, $FAR \ge 1$)	Исправьте поле, указанное в сообщении
«код «F1» повторяется»	Два фактора с одинаковым кодом	Сделайте коды уникальными
«строка 1: нужен заголовок с колонками score и label»	В CSV нет заголовка или он другой	Добавьте первую строку score,label (раздел 4.5)
«строка N: неизвестная метка …»	Метка не входит в список допустимых	Замените метку на genuine или impostor
«строка N: «…» не является числом»	В колонке оценки не число	Исправьте строку N в файле
«нет оценок злоумышленников (impostor)»	В файле только одна группа	Добавьте оценки второй группы
«Слишком большой запрос или файл»	Файл больше 50 МБ или больше 1 000 000 строк	Уменьшите выборку
«Ни один набор не удовлетворяет ограничениям»	Ограничения несовместимы	Ослабьте ограничение, которое мешает чаще всего (раздел 5.5)
«Задача слишком велика для выбранного метода»	Полный перебор выбран для более чем 20 факторов	Выберите «Автоматически» или «Целочисленное программирование»
«Нет связи с сервером» / «Сервер недоступен»	Сервер не запущен или ещё стартует	Выполните make health или docker compose ps; при необходимости перезапустите (раздел 2.5)
«Не найдено»	Эксперимент или каталог удалён	Обновите страницу истории или списка каталогов
«Доступ к камере запрещён»	Браузер не дал доступ к камере	Разрешите камеру в настройках сайта и обновите страницу
«Камера доступна только по HTTPS или на localhost»	Страница открыта по http с другого адреса	Откройте по https или на том же компьютере
«Нет доступа» / «Недостаточно прав»	Нет входа или роль не позволяет действие	Войдите под нужной ролью
«Нужен двухфакторный вход»	Сотрудник вошёл только по паролю	Подтвердите вход passkey в профиле

14 ЧАСТЫЕ ВОПРОСЫ

Почему оптимальный порог не совпадает с EER?

EER уравнивает доли ошибок, но не их цену. Если пропуск злоумышленника дороже, выгодно поднять порог: FAR снижается, FRR растёт, а суммарные потери уменьшаются. Порог совпадёт с EER, только если стоимости и разбросы оценок групп примерно равны.

Почему в статье EER ≈ 1,77 %, а программа выдаёт 1,786 %?

В статье значения округлены. Точный расчёт при заданных распределениях даёт 1,786 % и E = 0,1965, поэтому снижение потерь — 41,8 %, а не 41 %. Значения программы подтверждены независимым расчётом в SciPy; вывод статьи от этого не меняется.

Где взять FAR и FRR факторов?

Из паспорта или отчёта об испытаниях алгоритма (например, NIST FRVT), из литературы или из собственного пилота. Для порога лучше всего загрузить реальные оценки сравнителя в CSV — тогда результат не зависит от предположения о нормальном распределении.

Что делать, если факторов больше 20?

Выберите метод «Автоматически» или «Целочисленное программирование». Он работает до 50 факторов и доказывает оптимальность результата, но не строит полный рейтинг всех наборов.

Сохраняются ли данные после перезапуска?

Да. Эксперименты, каталоги и наборы оценок хранятся в базе данных в томе Docker и сохраняются после make down. Удалить их можно командой make reset-db.

Передаются ли данные в интернет?

Нет. Программа работает полностью на вашем компьютере; интернет нужен только при первой сборке, чтобы скачать базовые образы и модели распознавания.

Хранятся ли фотографии лиц?

Нет. Кадры обрабатываются в памяти сервиса распознавания и удаляются; в базе хранится только зашифрованный числовой шаблон и оценки сходства. Шаблон удаляется при отзыве согласия.

Почему новый порог не начал действовать сразу после калибровки?

Калибровка только предлагает новую версию политики. Действовать она начинает после утверждения администратором на вкладке «Политики» — так изменение риска всегда принимает человек, и его решение остаётся в журнале аудита.

Можно ли запустить программу без Docker?

Да, для разработчиков: нужны Node.js 22, pnpm 10 и PostgreSQL 16. Последовательность команд — make setup, make db, make migrate, make dev (подробно — в README.md).

15 ТИПОВОЙ СЦЕНАРИЙ: НАСТРОЙКА ВХОДА В БАНКОВСКОЕ ПРИЛОЖЕНИЕ

1) Отдел рисков оценивает стоимости ошибок: средний ущерб от мошеннического кредита и потери от отказа законному клиенту. Пусть $c_{FA}/c_{FR} = 200$.
2) Вендор передаёт оценки сравнителя лиц с пилота. Аналитик загружает их в разделе «Порог» → «Свои оценки (CSV)», задаёт $c_{FA} = 200$, $c_{FR} = 1$ и FAR не выше 1e-4.
3) Программа показывает оптимальный порог, потери по сравнению с EER и предупреждает, если оценок злоумышленников мало для подтверждения FAR.
4) Архитектор вводит каталог факторов (лицо с PAD, отпечаток, FIDO2, SMS-код) и ограничения «задержка не более 3000 мс, бюджет, FAR не выше 1e-6, не менее одного фактора с PAD», получает оптимальный набор и строит чувствительность к бюджету.
5) Эксперименты выгружаются в JSON и PNG и прикладываются к решению комитета; в карточке каждого эксперимента указаны входные данные и версия ядра — расчёт можно повторить при аудите.